

ETSI EN-304-623 0.0.4 (2025-09)



HARMONISED EUROPEAN STANDARD

CYBER; CRA; Essential cybersecurity requirements for boot managers

CAUTION:

Exercising one of the Principles of international standardization – Openness – and taking it to a different level, ETSI is piloting informal public consultations of the vertical standards in support of the Cyber Resilience Act at a much earlier stage than it is usual in the standardization world. In this context, please keep in mind that the standard draft herein is an INTERIM DRAFT, which expectably will be subject to substantial changes before its target publication date in the second semester of 2026.

Disclaimer

This **INTERIM DRAFT** document is provided for information and is for future development work within the ETSI Technical Committee CYBER EUSR Working Group (CYBER-EUSR) only. ETSI and its Members accept no liability for any further use/implementation of this Specification. Approved and published specifications and reports shall be obtained exclusively via the ETSI Documentation Service at <http://www.etsi.org/standards-search>

Commenting guidelines

Your comments to improve this early draft are very welcomed. To ensure the effectiveness of your contribution, please make sure to include the following elements in your comment:

1. Clear identification of the section of the draft your comment is referring to.
2. Objective proposal to delete content, add content or substitute content.
3. Concrete contribution (exact content you suggest including in the draft as an addition to, or in substitution of, existing content).
4. Brief rationale to justify the proposal (e.g. why the suggested content should be added an/or the existing content should be deleted or substituted). Please note that comments without concrete contributions will be noted but not

acted upon by ETSI CYBER-EUSR. We trust and value your expertise and therefore expect you to take this opportunity to proactively contribute to solving the issues you find while analysing this early draft.

How to comment

To comment or provide feedback on the present interim draft please visit : <https://labs.etsi.org/rep/stan4cra/en-304-623> and submit your comments as “issues” following the guidelines provided on this site.

Alternatively, you may also send your comments to: cybersupport@etsi.org using the “[ETSI Commenting Format for Open Consultation.xlsx](#)” available in <https://docbox.etsi.org/CYBER/EUSR/Open>

Should you need a step-by-step guide for drafting an ETSI deliverable, please consult the “[Principles for Drafting ETSI Deliverables](#)” document. Otherwise you may contact us at edithelp@etsi.org.

Reference

<Workitem>

Keywords

<keywords>

ETSI

650 Route des Lucioles

F-06921 Sophia Antipolis Cedex - FRANCE

Tel.: +33 4 92 94 42 00 Fax: +33 4 93 65 47 16

Siret N° 348 623 562 00017 - APE 7112B

Association à but non lucratif enregistrée à la

Sous-préfecture de Grasse (06) N° w061004871

Important notice

The present document may be made available in electronic versions and/or in print. The content of any electronic and/or print versions of the present document shall not be modified without the prior written authorization of ETSI. In case of

any existing or perceived difference in contents between such versions and/or in print, the prevailing version of an ETSI deliverable is the one made publicly available in PDF format on [ETSI deliver](#) repository.

Users should be aware that the present document may be revised or have its status changed, this information is available in the [Milestones listing](#).

If you find errors in the present document, please send your comments to the relevant service listed under [Committee Support Staff](#).

If you find a security vulnerability in the present document, please report it through our [Coordinated Vulnerability Disclosure \(CVD\)](#) program.

Notice of disclaimer & limitation of liability

The information provided in the present deliverable is directed solely to professionals who have the appropriate degree of experience to understand and interpret its content in accordance with generally accepted engineering or other professional standard and applicable regulations.

No recommendation as to products and services or vendors is made or should be implied.

No representation or warranty is made that this deliverable is technically accurate or sufficient or conforms to any law and/or governmental rule and/or regulation and further, no representation or warranty is made of merchantability or fitness for any particular purpose or against infringement of intellectual property rights.

In no event shall ETSI be held liable for loss of profits or any other incidental or consequential damages.

Any software contained in this deliverable is provided “AS IS” with no warranties, express or implied, including but not limited to, the warranties of merchantability, fitness for a particular purpose and non-infringement of intellectual property rights and ETSI shall not be held liable in any event for any damages whatsoever (including, without limitation, damages for loss of profits, business interruption, loss of information, or any other pecuniary loss) arising out of or related to the use of or inability to use the software.

Copyright Notification

No part may be reproduced or utilized in any form or by any means, electronic or mechanical, including photocopying and microfilm except as authorized by written permission of ETSI. The content of the PDF version shall not be modified without the written authorization of ETSI. The copyright and the foregoing restriction extend to reproduction in all media.

© ETSI yyyy.

All rights reserved.

Contents

[Intellectual Property Rights](#)

[Foreword](#)

[Modal verbs terminology](#)

[Executive summary](#)

[Introduction](#)

[1 Scope](#)

[1.1 General](#)

[1.2 In-scope products](#)

[1.3 Out-of-scope products](#)

[1.4 Composite products](#)

[2 References](#)

[2.1 Normative references](#)

[2.2 Informative references](#)

[3 Definition of terms and abbreviations](#)

[3.1 Terms](#)

[3.2 Abbreviations](#)

[4 Product context](#)

[4.1 General](#)

[4.2 Product overview](#)

[4.3 Architecture](#)

[4.3.1 Functional architecture](#)

[4.3.1.1 Basic Boot](#)

[4.3.1.2 Verified Boot](#)

[4.3.1.3 Measured Boot](#)

[4.3.2 Functional extensions](#)

[4.3.3 Boot manager capabilities](#)

[4.3.4 Trust boundaries](#)

[4.3.5 Resource constraints](#)

[4.3.6 Interfaces](#)

[4.4 Users](#)

[4.4.1 Actors](#)

[4.4.2 Interactions](#)

[4.5 Use cases](#)

[4.5.1 Deployment context](#)

[4.5.1.1 Physical access control](#)

[4.5.1.2 Network exposure](#)

[4.5.1.3 Administrative control](#)

[4.5.2 Use case examples](#)

[4.5.2.1 UC-HOME-1: Embedded IoT device \(smart speaker, sensor\)](#)

[4.5.2.2 UC-HOME-2: Consumer home entertainment device \(ie. smart TV\)](#)

[4.5.2.3 UC-HOME-3: Consumer home router](#)

[4.5.2.4 UC-STAT-1: Personal desktop computer](#)

[4.5.2.5 UC-STAT-2: Enterprise-managed workstation](#)

[4.5.2.6 UC-STAT-3: Thin client terminal](#)

[4.5.2.7 UC-MOB-1: Smartphone](#)

[4.5.2.8 UC-MOB-2: Tablet](#)

[4.5.2.9 UC-MOB-3: Personal laptop](#)

[4.5.2.10 UC-MOB-4: Enterprise-managed corporate laptop](#)

[4.5.2.11 UC-INFRA-1: Datacenter server](#)

[4.5.2.12 UC-INFRA-2: Cloud service machine](#)

[4.5.2.13 UC-INFRA-3: Edge computing device](#)

[4.5.2.14 UC-INFRA-4: Network infrastructure device](#)

[4.5.2.15 UC-IND-1: Industrial control system](#)

[4.5.2.16 UC-IND-2: Building automation controller](#)

[4.5.2.17 UC-MED-1: Diagnostic equipment](#)

[4.5.2.18 UC-MED-2: Patient monitoring device](#)

[4.5.2.19 UC-MED-3: Medical IT infrastructure](#)

[4.5.2.20 UC-REG-1: Payment terminal or ATM](#)

[4.5.2.21 UC-REG-2: Voting machine](#)

- [4.5.2.22 UC-REG-3: Gaming/gambling terminal](#)
- [4.5.2.23 UC-REG-4: Government/military system](#)
- [4.5.2.24 UC-DEV-1: Development board](#)
- [4.5.2.25 UC-DEV-2: Continuous integration system](#)
- [4.5.2.28 UC-DEV-3: Security research platform](#)
- [4.6 Threats and Risk Considerations](#)
 - [4.6.1 Threat landscape](#)
 - [4.6.2 Risk factors](#)
 - [4.6.3 Capability-based risk considerations](#)
- [5 Requirements](#)
 - [5.1 Applicable requirements](#)
 - [5.1.1 General](#)
 - [5.1.2 Capability-based conditions](#)
 - [5.1.2.1 Introduction](#)
 - [5.1.2.2 Boot architecture conditions](#)
 - [5.1.2.3 Update capability conditions](#)
 - [5.1.2.4 Boot source conditions](#)
 - [5.1.2.5 Configuration management conditions](#)
 - [5.1.2.6 Hardware security conditions](#)
 - [5.1.2.7 Recovery capability conditions](#)
 - [5.1.3 Capability assessment](#)
 - [5.1.4 Requirement structure and applicability](#)
 - [5.2 Security by design](#)
 - [5.2.1 General](#)
 - [5.2.2 Secure by Design](#)
 - [5.2.2.1 General](#)
 - [5.2.2.2 Input](#)
 - [5.2.2.3 Requirements](#)
 - [5.2.2.3 Output](#)
 - [5.2.2.4 Assessment criteria](#)
 - [5.3 Secure by Default Configuration](#)
 - [5.3.1 General](#)
 - [5.3.2 Secure by default configuration](#)
 - [5.3.2.1 General](#)
 - [5.3.2.2 Input](#)
 - [5.3.2.3 Requirements](#)
 - [5.3.2.4 Output](#)
 - [5.3.2.5 Assessment criteria](#)
 - [5.4 Access Control](#)
 - [5.4.1 General](#)
 - [5.4.2 Authentication and access control](#)
 - [5.4.2.1 General](#)
 - [5.4.2.2 Input](#)
 - [5.4.2.3 Requirements](#)
 - [5.4.2.4 Output](#)
 - [5.4.2.5 Assessment criteria](#)
 - [5.5 Data Protection](#)
 - [5.5.1 General](#)
 - [5.5.2 Confidentiality protection](#)
 - [5.5.2.1 General](#)
 - [5.5.2.2 Input](#)
 - [5.5.2.3 Requirements](#)
 - [5.5.2.4 Output](#)
 - [5.5.2.5 Assessment criteria](#)
 - [5.6 Integrity Protection](#)
 - [5.6.1 General](#)
 - [5.6.2 Boot chain integrity](#)
 - [5.6.2.1 General](#)
 - [5.6.2.2 Input](#)
 - [5.6.2.3 Requirements](#)
 - [5.6.2.4 Output](#)
 - [5.6.2.5 Assessment criteria](#)

5.7 Data Minimization

5.7.1 General

5.7.2 Minimal data processing

5.7.2.1 General

5.7.2.2 Input

5.7.2.3 Requirements

5.7.2.4 Output

5.7.2.5 Assessment criteria

5.8 Availability and Resilience

5.8.1 General

5.8.2 Recovery and fault tolerance

5.8.2.1 General

5.8.2.2 Input

5.8.2.3 Requirements

5.8.2.4 Output

5.8.2.5 Assessment criteria

5.9 Impact Minimization

5.9.1 General

5.9.2 System impact minimization

5.9.2.1 General

5.9.2.2 Input

5.9.2.3 Requirements

5.9.2.4 Output

5.9.2.5 Assessment criteria

5.10 Attack Surface Minimization

5.10.1 General

5.10.2 Attack surface reduction

5.10.2.1 General

5.10.2.2 Input

5.10.2.3 Requirements

5.10.2.4 Output

5.10.2.5 Assessment criteria

5.11 Monitoring and Logging

5.11.1 General

5.11.1 General

5.11.2 Boot event logging

5.11.2.1 General

5.11.2.2 Input

5.11.2.3 Requirements

5.11.2.4 Output

5.11.2.5 Assessment criteria

5.12 Vulnerability Management

5.12.1 General

5.12.2 Vulnerability handling

5.12.2.1 General

5.12.2.2 Input

5.12.2.3 Requirements

5.12.2.4 Output

5.12.2.5 Assessment criteria

5.13 Security Testing and Review

5.13.1 General

5.13.2 Security validation

5.13.2.1 General

5.13.2.2 Input

5.13.2.3 Requirements

5.13.2.4 Output

5.13.2.5 Assessment criteria

5.14 Specific functional requirements

Annex A (normative): Relationship between the present document and the essential requirements of EU Regulation 2024/2847

Annex B (informative): Relationship between the present document and any related ETSI standards

B.1 Relationship to ETSI standards

[Annex C \(informative\): Risk identification and assessment methodology](#)

[C.1 Assets](#)

[C.2 Threat actors](#)

[C.3 Boot-specific threats](#)

[C.4 Specific considerations for long-lifetime devices](#)

[Annex D \(informative\): Security profiles](#)

[D.1 Profile application guidance](#)

[History](#)

Intellectual Property Rights

Essential patents

IPRs essential or potentially essential to normative deliverables may have been declared to ETSI. The declarations pertaining to these essential IPRs, if any, are publicly available for **ETSI members and non-members**, and can be found in ETSI SR 000 314: *“Intellectual Property Rights (IPRs); Essential, or potentially Essential, IPRs notified to ETSI in respect of ETSI standards”*, which is available from the ETSI Secretariat. Latest updates are available on the [ETSI IPR online database](#).

Pursuant to the ETSI Directives including the ETSI IPR Policy, no investigation regarding the essentiality of IPRs, including IPR searches, has been carried out by ETSI. No guarantee can be given as to the existence of other IPRs not referenced in ETSI SR 000 314 (or the updates on the ETSI Web server) which are, or may be, or may become, essential to the present document.

Trademarks

The present document may include trademarks and/or tradenames which are asserted and/or registered by their owners. ETSI claims no ownership of these except for any which are indicated as being the property of ETSI, and conveys no right to use or reproduce any trademark and/or tradename. Mention of those trademarks in the present document does not constitute an endorsement by ETSI of products, services or organizations associated with those trademarks.

DECT™, **PLUGTESTS™**, **UMTS™** and the ETSI logo are trademarks of ETSI registered for the benefit of its Members. **3GPP™**, **LTE™** and **5G™** logo are trademarks of ETSI registered for the benefit of its Members and of the 3GPP Organizational Partners. **oneM2M™** logo is a trademark of ETSI registered for the benefit of its Members and of the oneM2M Partners. **GSM®** and the GSM logo are trademarks registered and owned by the GSM Association.

Foreword

DRAFT FOREWORD - DO NOT CONSIDER THE CONTENT

This draft Harmonised European Standard (EN) has been produced by ETSI Technical Committee Cyber Working Group for EUSR (CYBER-EUSR), and is now submitted for the combined Public Enquiry and Vote phase of the ETSI Standardisation Request deliverable Approval Procedure (SRdAP).

The present document has been prepared under the Commission's standardisation request C(2025) 618 final to provide one voluntary means of conforming to the requirements of Regulation (EU) No 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements and amending Regulations (EU) No 168/2013 and (EU) No 2019/1020 and Directive (EU) 2020/1828 (Cyber Resilience Act).

Once the present document is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of the present document given in table A.1 confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

Transposition table

The Harmonised Standard shall have appropriate transposition periods specified. A Harmonised Standard confers presumption of conformity when it has been published in the Official Journal of the European Union (OJEU) and transposed by a member state.

The Technical Body may propose different dates to the default ones (3, 6, 18). Technical Bodies who wish to propose different dates are advised to indicate this clearly in the approved committee draft.

Proposed national transposition dates	
Date of latest announcement of this EN (doa):	3 months after ETSI publication
Date of latest publication of new National Standard	
or endorsement of this EN (dop/e):	6 months after doa
Date of withdrawal of any conflicting National Standard (dow):	18 months after doa

The Technical Body should advise the ETSI Secretariat if the above default national transposition dates are inappropriate for the particular standard.

Modal verbs terminology

In the present document “**should**”, “**should not**”, “**may**”, “**need not**”, “**will**”, “**will not**”, “**can**” and “**cannot**” are to be interpreted as described in clause 3.2 of the [ETSI Drafting Rules](#) (Verbal forms for the expression of provisions).

“**must**” and “**must not**” are **NOT** allowed in ETSI deliverables except when used in direct citation.

Executive summary

Introduction

The present document is a European harmonised standard that defines cybersecurity requirements for boot managers as products with digital elements. Demonstrating compliance with this standard is not necessary, but doing so provides a presumption of conformity with Regulation (EU) 2024/2847, the Cyber Resilience Act (CRA).

It addresses boot managers identified in Annex III, Point 8 as important products with digital elements (Class I), in the Annex to Commission Implementing Regulation 2025/XXX on the technical description of the categories of important and critical products with digital elements and as specified in standardisation request C(2025) 618, line item 23.

1 Scope

1.1 General

The scope covers components that participate in or manage the boot process, from initial power-on through the establishment of the chain of trust to the handover to the boot target.

This standard applies a capability-based approach to requirements, where the presence of specific technical capabilities in a boot manager determines which security requirements apply, regardless of the intended deployment and implementation context. This ensures proportionate security measures while maintaining clarity for manufacturers who cannot predict where their boot managers will ultimately be deployed.

1.2 In-scope products

Products in scope include boot management software and firmware that controls or participates in the boot process from power-on until handover to the boot target, whether integrated into system firmware or provided as standalone components, regardless of their distribution model. This category includes but is not limited to:

- System firmware that performs hardware initialization and boot management
- Standalone bootloaders that manage boot target selection and loading
- Embedded boot firmware commonly used in embedded and IoT devices
- Network boot implementations that enable remote boot capabilities
- Platform initialization firmware that executes from power-on until boot manager control
- Components that establish, verify, or extend the chain of trust during boot

NOTE: Boot managers may be implemented as single-stage bootloaders (direct loading) or multi-stage bootloaders (staged verification and loading processes).

#FIXME Is the scope sufficient?

1.3 Out-of-scope products

This standard does not cover products in use in contexts other than those identified in Annex A. It does not cover:

- Operating systems
- Hypervisors

Operating systems provide runtime services for applications to interact with system resources and peripherals. While they may include boot management functionality, these are secondary to their primary purpose as an operating system.

Hypervisors are primarily designed for virtualization and resource management rather than boot management. Type 1 hypervisors may incorporate boot functionality, but the complete hypervisor product is out of scope. However, discrete

boot management components within hypervisors that can be separately identified, configured, or updated may fall within scope if they meet the technical boundaries defined in this standard.

The boundary is determined by whether the component executes between power-on and boot target handover and can affect the boot sequence or chain of trust.

NOTE: Components that cannot be updated post-manufacture are addressed with specific provisions in Section 5.

#FIXME More out-of-scope clarification needed?

1.4 Composite products

When boot manager functionality is integrated into larger products (such as operating systems, hypervisors, or embedded devices), the product manufacturer demonstrates conformance through evaluation of the complete product, with boot manager requirements may assessed as part of the whole.

Products integrating boot manager functionality may:

- Apply this standard to boot manager or firmware components only
- Demonstrate conformance through composite evaluation
- Reference relevant requirements without claiming full conformance

2 References

2.1 Normative references

Normative references are not applicable in the present document.

2.2 Informative references

References are either specific (identified by date of publication and/or edition number or version number) or nonspecific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, ETSI cannot guarantee their long term validity.

The following referenced documents may be useful in implementing an ETSI deliverable or add to the reader's understanding but are not required for conformance to the present document.

- [i.x] Regulation (EU) 2024/2847 of the European Parliament and of the Council of 23 October 2024 on horizontal cybersecurity requirements for products with digital elements (Cyber Resilience Act)
- [i.x] Commission Implementing Regulation (Draft): "Technical description of the categories of important and critical products with digital elements"
- [i.x] C(2025) 618: "Commission Implementing Decision on a standardisation request as regards cybersecurity of products with digital elements in support of Regulation (EU) 2024/2847"
- [i.x] ETSI EN 303 645: "Cyber Security for Consumer Internet of Things: Baseline Requirements"
- [i.x] ETSI TS 103 732-5: "CMD Protection Profiles - Part 5: Bootloader & Root of Trust Protection Profile Module"

3 Definition of terms and abbreviations

3.1 Terms

For the purposes of the present document, the [following] terms [given in ... and the following] apply:

Boot managers: Software or firmware component that controls the boot process and allow to manage multiple boot targets or boot configurations after power-on or reset. For the use in the document it also serves as a catch-all term.

Boot sequence: Ordered series of operations performed during system startup.

Chain of Trust: Sequential verification where each boot component validates the next, establishing security from hardware root to the operating system.

Verified boot: Generic term for cryptographic verification of boot components before execution to ensure only authorized code runs during system initialization.

Secure Boot: Specific UEFI implementation of verified boot that uses certificates and signature databases to verify boot components. When capitalized, refers exclusively to the UEFI Secure Boot feature.

Measured boot: Recording cryptographic measurements of boot components before execution for attestation without blocking execution.

Hardware security component: Generic term for hardware-based security modules that provide cryptographic services and secure storage (includes but not limited to TPM, HSM, TEE, Secure Element)

Network boot: Loading boot components from network sources using protocols such as PXE or HTTPS Boot.

Recovery boot: Specialized boot process designed to restore system functionality after failures.

Root of Trust: The foundation of the boot security chain, typically implemented in immutable code or hardware.

Attestation: Process of providing cryptographic evidence about boot state to a verifier.

Boot component: Any code or data loaded during the boot process.

Boot target: Software component to which the boot manager transfers control upon successful completion of its designated function, such as an operating system kernel, hypervisor, another boot loader, or an embedded application.

Boot device: Any storage medium or interface from which boot code can be loaded and executed, including internal storage, removable media, or network sources.

Firmware: Low-level software stored in non-volatile memory on the device/product that provides hardware initialization and runtime services, including boot managers.

Platform initialization firmware: Code that typically executes from power-on until the actual boot management takes place.

Physical presence: Requirement for a user to be physically at the device location with unrestricted access to the device to perform certain security-sensitive operations, typically verified through local keyboard input, or button presses.

Air-gapped: System or network physically isolated from unsecured networks, particularly the internet, with no network connectivity for data transfer.

Immutable components: Components that cannot be modified after manufacture or initial programming.

Rollback protection: Security mechanism preventing installation of older firmware versions that may contain known vulnerabilities.

Factory reset: Process of restoring boot manager to its original manufactured state, removing all user configuration and enrolled credentials.

Capability: Technical feature or function that can be implemented in a boot manager, independent of how or where the boot manager is deployed.

Capability assessment: Formal declaration documenting all conditions applicable to their boot manager product, which determines the security requirements that apply.

Baseline requirement: Security requirement applicable to all boot managers regardless of their capabilities or deployment context.

Conditional requirement: Security requirement that applies only when specific conditions are present in the boot manager, as declared in the Capability Assessment.

#FIXME Terms

3.2 Abbreviations

For the purposes of the present document, the [following] abbreviations [given in ... and the following] apply:

- BIOS: Basic Input/Output System
- HSM: Hardware Security Module
- NVRAM: Non-Volatile Random Access Memory
- OS: Operating System
- PXE: Preboot Execution Environment
- ROM: Read-Only Memory
- SBOM: Software Bill of Materials
- TEE: Trusted Execution Environment
- TPM: Trusted Platform Module
- UEFI: Unified Extensible Firmware Interface

NOTE: TPM and HSM are examples of hardware security components. The generic term ‘hardware security component’ is used throughout this document unless referring to specific implementation examples.

#FIXME Abbreviations

4 Product context

4.1 General

The product context identifies the operational characteristics, deployment environments, and functional boundaries that determine applicable security requirements. Boot managers are characterized by their capabilities - specific features and functions that trigger different security requirements.

4.2 Product overview

Boot managers include components that execute from power-on through boot target handover and establishing the platform's security posture for system operations. They may operate with or without cryptographic verification mechanisms, as detailed in the architectural descriptions in Section 4.3.1.

Boot managers typically reside in non-volatile storage (SPI flash, eMMC boot partitions, QSPI) and are loaded into memory for execution. The boot target may be an operating system, hypervisor, another bootloader, embedded application, or recovery environment, and may reside in the same or different storage media.

4.3 Architecture

4.3.1 Functional architecture

For the purposes of this standard, the choice of boot architecture represents the fundamental security capability of a boot manager. This architectural choice determines the boot manager's core baseline security requirements.

Basic Boot provides no cryptographic verification, focusing solely on loading and executing boot components. This represents the minimum viable boot capability.

Verified Boot implements cryptographic verification with enforcement, preventing execution of unauthorized code.

Measured Boot adds cryptographic measurement and recording without enforcement, provides auditability without blocking execution.

The architectural pattern chosen is not merely a design decision but the primary capability that defines which security requirements apply. A boot manager's architecture cannot be changed post-deployment, it is an intrinsic property. Additional capabilities augment but do not replace the security properties provided by the chosen architecture.

4.3.1.1 Basic Boot

Basic boot implements sequential stage execution without cryptographic verification or integrity verification mechanisms.

The system begins with power-on, proceeds through hardware initialization, and continues with sequential stage execution where each stage directly loads and executes the next until the boot target is reached.

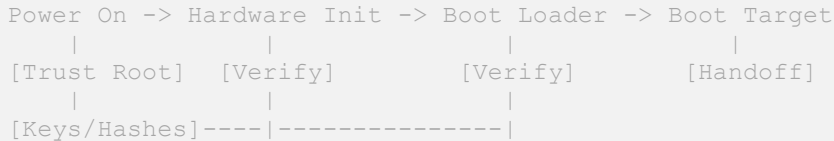


4.3.1.2 Verified Boot

Verified boot implements cryptographic verification with enforcement throughout the boot process. Components are cryptographically verified before execution, creating a verification chain from power-on through boot target execution.

Components are verified against stored cryptographic signatures or hashes and if verification fails the system halts the boot process and potentially triggers recovery mode. Initial verification material (keys or hashes) may be stored in hardware-protected memory, fuses, or one-time programmable storage.

Systems implementing verified boot require cryptographic verification capabilities and secure storage for verification material.

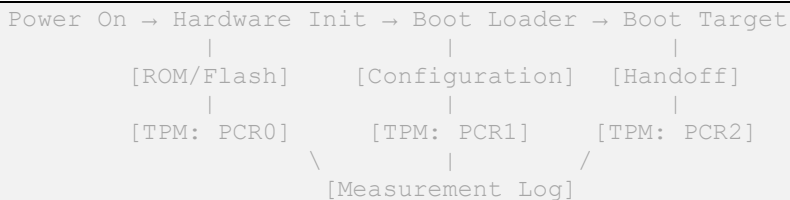


4.3.1.3 Measured Boot

Measured boot records cryptographic measurements of each boot stage without preventing execution. During initialization, the system activates measurement capabilities and records a cryptographic hash of each subsequent stage into secure storage.

Each stage computes a cryptographic hash of the next component and extends it into designated registers, and the boot process continues regardless of measurement values. The resulting measurement log provides an attestable record of the boot sequence that can be verified against known-good values or reference measurements.

This architecture requires hardware or firmware capable of secure measurement storage and reporting. The given examples below assumes the presence of a TPM, the PCR registers are examples and can be chosen per implementation.



4.3.2 Functional extensions

Additional functions such as network boot, multi-boot selection, or recovery modes can be incorporated into any of the architectures described in Section 4.3.1.

4.3.3 Boot manager capabilities

The architectural choices and functional extensions described in the previous sections result in specific capabilities that determine which security profiles apply:

- Boot architecture: As defined in Section 4.3.1 (Basic, Verified, or Measured)
- Update capability: Can be none, config-only, partial, or full
- Network boot: Supported or not supported
- Portable media boot: Supported or not supported
- Hardware security features: Hardware security component integration present or absent
- Configuration: User-modifiable settings or fixed configuration
- Recovery mechanisms: Recovery mode available or not
- Boot target selection: Multiple boot targets or single target

These capabilities correspond to the formal conditions defined in Section 5.1.2, which determine the applicable security requirements. Manufacturers shall assess which capabilities are present in their product and declare them in the Capability Assessment as specified in Section 5.1.3.

4.3.4 Trust boundaries

Boot managers operate across multiple trust boundaries where different security domains interface.

The involved trust components may be delivered by different parties, e.g. root of trust by hardware vendor, security hashes for different stages by firmware/board OEM, or certificates by operating system vendors.

- **Hardware boundary:** Components the boot manager must trust without verification capability, including CPU microcode, platform security processors providing opaque services, or immutable boot ROM.
- **Storage boundary:** Components requiring verification before use, including all data read from storage media, configuration data, and boot components that may have been tampered with or corrupted.
- **Network boundary:** Untrusted input requiring complete verification, including all network-sourced boot components, protocol data, and remote configuration.
- **Operating system boundary:** Components to which the boot manager transfers control, including operating systems, hypervisors, and runtime services. This boundary is bidirectional when the operating system performs updates to the boot manager.
- **Control authority boundary:** Delineation of ultimate authority over boot manager configuration and debug access, which shall reside with device owners or administrators, not manufacturers or vendors.

These boundaries define where boot managers can enforce security properties versus where they must rely on trust assumptions or external security mechanisms.

4.3.5 Resource constraints

Boot managers operate under significant resource limitations:

- **Storage:** Restricted firmware storage capacity shared with other components
- **Computation:** No OS services, drivers, or shared libraries during early stages
- **Time:** Boot performance requirements limiting security operations
- **Power:** Energy constraints in battery-powered and embedded devices
- **Environment:** Temperature, vibration, and reliability requirements in industrial deployments
- **Aging:** Flash wear, bit rot, component degradation over lifecycle

These constraints influence architectural decisions and security vs. performance trade-offs.

4.3.6 Interfaces

Boot managers receive inputs, for example hardware reset signals, configuration data, boot media, network packets, or user input, and produce outputs, like the system state, measurement logs, or error codes. Boot managers interact through various technical interfaces:

- **Storage interfaces:** SPI flash, USB, eMMC, NVMe, SATA with different protection mechanisms
- **Network interfaces:** Ethernet, WiFi supporting PXE, HTTP Boot, iSCSI protocols
- **Debug interfaces:** JTAG, SWD, UART, USB, SPI programmers requiring access control
- **User interfaces:** Serial console, display output, keyboard, remote management (IPMI/BMC)
- **Hardware security interfaces:** Hardware security component connections (SPI/I2C or other protocols)

- Runtime interfaces: UEFI runtime services, ACPI tables, SMM/SMI interfaces

Interface lockdown hierarchy:

- Owner/administrator has ultimate control
- Manufacturer access only with owner consent
- No hidden or undocumented access methods

The control interfaces of boot managers include configuration utilities, update mechanisms, recovery modes, or remote management protocols.

4.4 Users

Boot managers operate mostly without any user interaction during normal operation, with security decisions predetermined by configuration rather than runtime user input.

4.4.1 Actors

Legitimate actors with direct system access include:

- Manufacturers during production and initial provisioning
- System integrators during deployment
- Distributors and resellers during inventory management
- System administrators for enterprise configuration
- End users for boot selection
- Service technicians during maintenance
- Testing laboratories for certification and testing
- Forensic analysts during investigations
- Security researchers for vulnerability assessment

4.4.2 Interactions

- Manufacturing phase: Fuse programming, key provisioning, initial firmware installation, testing
- Configuration phase: Use of setup and configuration tools
- Boot phase: Physical presence detection, boot target selection, recovery mode activation
- Maintenance phase: Updates, rollbacks, resets
- Decommissioning phase: Secure erasure, key destruction, decommissioning verification

These interactions represent points where boot manager security can be modified, backdoored or bypassed, requiring appropriate access controls and authentication mechanisms.

Interactions requiring special attention:

- Device resale or transfer
- Return for service/warranty
- Employee termination (enterprise devices)
- End-of-life disposal

4.5 Use cases

4.5.1 Deployment context

Boot managers face different threat exposures based on their deployment environment.

4.5.1.1 Physical access control

- Protected: Authorization required, access monitored (data centers, managed offices)
- Unprotected: Accessible without authorization (consumer devices, field equipment)

4.5.1.2 Network exposure

- Isolated: Air-gapped or no network capability
- Managed: Corporate networks with access controls
- Hostile: Internet-facing or untrusted networks

4.5.1.3 Administrative control

- Centrally managed: Enterprise control over configuration and updates
- User managed: End user controls configuration
- Vendor managed: Manufacturer controls updates and configuration

4.5.2 Use case examples

The following use cases provide a high-level overview how boot managers operate within various device types. Each use case reflects the boot manager's roles as component that must balance device-specific requirements with security enforcement.

4.5.2.1 UC-HOME-1: Embedded IoT device (smart speaker, sensor)

- Device has no user interface for boot configuration
- Cannot be updated independently from main firmware
- Operates on battery or low power
- No network connectivity during boot
- If compromised, entire device must be replaced
- May be placed in private spaces (bedrooms, bathrooms)
- May be purchased second-hand without factory reset
- Firmware may outlive vendor support by years

4.5.2.2 UC-HOME-2: Consumer home entertainment device (ie. smart TV)

- No keyboard, remote control interface only
- Accepts USB media
- May access online content
- Ability to send local (potentially private) data to remote servers via internet connection

- May automatically download updates from vendor servers
- Children may attempt to bypass parental controls
- Disposed with personal viewing history intact
- Service technicians may need diagnostic boot modes
- Integrated cameras/microphones with storage of private media

4.5.2.3 UC-HOME-3: Consumer home router

- Exposed to untrusted network
- Device stores credentials (ISP, WiFi)
- Provides factory reset via physical button
- May automatically download firmware from vendor servers
- Always-on device, rarely rebooted
- May be accessible to guests and visitors in physical space
- May have vendor backdoor for ISP support
- May cascade failures to connected devices
- Can influence all connected devices
- Can access private data on the internal network

4.5.2.4 UC-STAT-1: Personal desktop computer

- Allows user to select boot device
- Permits disabling verified boot for compatibility
- Stores arbitrary personal files and credentials
- May store multiple OS entries
- May be modified with hardware additions
- Update capability of security certificates by an OS vendor
- Gaming users may disable security for performance
- Enthusiasts may overclock requiring custom settings
- Dual-boot configurations complicate secure boot

4.5.2.5 UC-STAT-2: Enterprise-managed workstation

- Device owned by organization, not user
- Stores configured boot policies
- Enforces secure boot without override
- Measured boot state for disk encryption
- Requires admin credentials for changes
- Reports attestation to corporate network

- Must survive employee termination procedures
- Regulatory compliance may require specific configurations

4.5.2.6 UC-STAT-3: Thin client terminal

- Stores only network boot configuration
- Downloads OS image from server
- Has no local OS storage
- Resets to clean state on reboot
- May be used in public spaces (libraries, hotels)
- Network outage leaves device unusable
- Server compromise affects all terminals connected

4.5.2.7 UC-MOB-1: Smartphone

- Stores device-unique cryptographic keys in hardware
- Collects personal data including biometrics for unlock
- Frequently travels through untrusted environments
- Target of theft, carried through borders
- Integrates with payment and banking systems via apps
- Enforces manufacturer boot policy by default
- User may wipe data on the device remotely
- Law enforcement may attempt forced unlock
- Repair shops need diagnostic access without data exposure
- Trade-in require verifiable secure wipe
- Screen damage may prevent user interaction for recovery
- Usually receives over the air updates on a regular basis
- Effort by user to keep updated is lower compared to servers or workstations (can be done by children)

4.5.2.8 UC-MOB-2: Tablet

- Similar to UC-MOB-1
- May be shared in the household or with guests
- May be shared with children
- Used for point-of-sale in businesses

4.5.2.9 UC-MOB-3: Personal laptop

- Similar to UC-STAT-1
- Target of theft, carried through borders

- Exposed to untrusted network
- Lid-close doesn't mean powered-off
- Powered-off may be doesn't mean really off-state
- "Evil maid" attacks
- Customs/border inspection scenarios
- Coffee shop shoulder-surfing during boot

4.5.2.10 UC-MOB-4: Enterprise-managed corporate laptop

- Similar to UC-STAT-2
- Travels with employee
- May be remotely wiped or bricked if reported stolen
- Crossing international borders with encrypted data
- Temporary contractor access requirements
- Devices by employees may be targeted specifically due to corporate function

4.5.2.11 UC-INFRA-1: Datacenter server

- Physical access to systems restricted
- Configured via remote management interface
- Stores network boot parameters
- Not accessible to end users
- Must boot headless without user intervention
- Decommissioning requires verifiable secure wipe

4.5.2.12 UC-INFRA-2: Cloud service machine

- Loads hypervisor instead of OS
- Stores VM boot configurations
- Validates hypervisor integrity
- Manages nested boot processes
- Virtual machine boot images
- No physical security boundary
- Customer VM images may contain malware
- Multi-tenant isolation requirements
- Multiple different users at a time
- No control of the type of user (normal user, enterprise user, state actor)

4.5.2.13 UC-INFRA-3: Edge computing device

- Deployed in remote locations
- Limited physical security compared to UC-INFRA-1 and UC-INFRA-2
- Must operate autonomously
- Network connectivity may be intermittent
- Environmental extremes (temperature, humidity)
- Wildlife or weather damage possible
- Maintenance visits expensive/rare
- Cellular backup connectivity for recovery

4.5.2.14 UC-INFRA-4: Network infrastructure device

- Router, switch, firewall
- Always-on operation
- Exposed to hostile network traffic
- Critical to network operation
- Configuration errors affect entire network
- Targeted by nation-state actors
- Backdoor concerns from manufacturer
- Operates 24/7 with rare reboots

4.5.2.15 UC-IND-1: Industrial control system

- Critical infrastructure
- Controls physical processes
- Safety-critical operation
- 15-20 year lifecycle
- May be air-gapped but USB can be used
- May require support for legacy protocols

4.5.2.16 UC-IND-2: Building automation controller

- HVAC, lighting, access control
- Integration with legacy systems
- 15-20 year lifecycle
- Contractors need temporary access
- Energy efficiency monitoring
- Fire/safety system integration

4.5.2.17 UC-MED-1: Diagnostic equipment

- MRI, CT scanner, X-ray
- Patient data protection
- Scheduled maintenance windows

4.5.2.18 UC-MED-2: Patient monitoring device

- Continuous operation required
- Patient safety critical
- Visitor tampering
- Fluid ingress risks

4.5.2.19 UC-MED-3: Medical IT infrastructure

- Hospital information systems
- Electronic health records
- Ransomware recovery critical

4.5.2.20 UC-REG-1: Payment terminal or ATM

- Public physical exposure
- Stores tamper detection state
- Halts boot if security check fails
- Regulatory compliance
- Cash cassette access controls
- Surveillance camera present
- Transaction during network outages

4.5.2.21 UC-REG-2: Voting machine

- Public verifiability required
- Sealed between elections
- Comprehensive audit trail
- Storage between elections in uncontrolled environments

4.5.2.22 UC-REG-3: Gaming/gambling terminal

- Anti-tampering required
- Detailed logging for disputes
- Random number generator certification
- Payout percentage verification
- Proper gambler lockout systems

- Cash handling integration
- Surveillance systems
- Tournament mode configurations

4.5.2.23 UC-REG-4: Government/military system

- Classified information processing
- Strict access controls
- Hardware supply chain verification
- Electromagnetic emanation controls

4.5.2.24 UC-DEV-1: Development board

- Frequent reflashing
- Debug access
- Security features often disabled
- Experimental code execution
- Power supply instabilities

4.5.2.25 UC-DEV-2: Continuous integration system

- Automated testing
- Frequent boot cycles
- Multiple configurations tested
- Rollback capability essential
- Test image library management
- Malware in test suites
- Container/VM hybrid environments

4.5.2.28 UC-DEV-3: Security research platform

- Intentional vulnerability testing
- Forensic analysis capability
- Extensive logging
- Isolation from production
- Exploit development workspace

#FIXME Add more use cases from below?

- Smart watches
- Fitness tracker
- Vehicle infotainment system

- Vehicle control unit
- Fleet management device
- Digital signage/billboard
- LED lighting controller
- Scientific instrument controller
- Satellite/spacecraft systems
- Broadcasting equipment
- Drone/UAV controller
- Retail self-checkout kiosk
- Smart meter
- Elevator control system
- Prison/detention facility systems
- Agricultural equipment
- Mining/drilling equipment
- Food service equipment
- Fitness/gym equipment
- Parking systems
- Emergency communication systems
- Vending machines
- 3D printer
- Logic analyzer
- Solar inverter
- Electric vehicle charger
- Cryptocurrency hardware wallet
- Bluetooth/WiFi module
- Storage controller (RAID/HBA)
- Network card
- KVM switch
- UPS (Uninterruptible Power Supply)
- Access card reader
- GPS tracker
- Weather station

4.6 Threats and Risk Considerations

4.6.1 Threat landscape

Boot managers face unique threats due to their privileged position as the first code executed and their role in establishing platform trust. These threats differ from OS-level threats in persistence, detectability, and impact.

The primary threat categories relevant to boot managers include:

- Pre-boot attacks: Attempts to compromise the boot process before security services are available
- Persistent firmware threats: Malicious code designed to survive OS reinstallation
- Physical access attacks: Exploitation of hardware interfaces and direct device access
- Supply chain attacks: Compromise during manufacturing, distribution, or maintenance
- Rollback attacks: Attempts to revert to vulnerable versions
- Network-based attacks: Threats specific to network boot operations

Temporal threat factors:

- Evolution of threats over device lifetime (especially for 15+ year deployments)
- Hardware degradation effects security
- Cryptographic algorithm deprecation

4.6.2 Risk factors

Boot managers present unique risks due to their position as the foundation of system security. Risk factors include:

- Privileged position (highest privilege level)
- Persistence (survives OS reinstall)
- Invisibility (below OS visibility)
- Trust establishment (foundation for all security)

4.6.3 Capability-based risk considerations

While this standard applies requirements based on technical capabilities rather than risk assessment, manufacturers should consider deployment risks when selecting which capabilities to implement:

- Network boot capability: Introduces network attack surface and protocol vulnerabilities
- Update capability: Enables patching but requires secure update infrastructure and introduces supply chain risks
- Hardware security features: Provides stronger guarantees but increases cost and complexity
- Configuration capability: Enables flexibility but increases attack surface and misconfiguration risks

NOTE: Security requirements apply based on capabilities built into the product, not deployment context. Disabled features can be re-enabled by attackers, and dormant code paths remain exploitable. Risk assessment should inform capability selection during design, while deployment context should inform configuration and operational controls.

For detailed threat analysis including threat actors, attack vectors, and risk assessment methodology, see Annex C. Manufacturers shall conduct threat modeling for their boot manager implementation as required in Section 5.2. The requirements in Section 5 are designed to mitigate these threats through defense-in-depth security controls.

5 Requirements

5.1 Applicable requirements

5.1.1 General

This clause establishes cybersecurity requirements for boot managers within the scope of the present document. The requirements implement the essential cybersecurity requirements specified in Annex I Part I and Part II of Regulation (EU) 2024/2847.

Each requirement in this section either (i) specifies no applicability conditions, meaning the requirement applies to all boot managers, or (ii) specifies applicability conditions, meaning the requirement applies only when the specified conditions are present in the product.

The presence of a capability in the product, whether enabled by default or through configuration, triggers all associated requirements. Manufacturers shall meet all applicable requirements based on the capabilities present in their product as declared in the Capability Assessment. Manufacturers cannot avoid requirements by shipping capabilities in a disabled state.

The requirements address the security properties necessary for boot managers operating in various deployment contexts and threat environments. Boot managers are expected to establish initial trust without prior security services, operate in resource-constrained environments, and protect against persistent firmware compromises. The conditional applicability ensures proportionate security measures while maintaining essential security properties across all boot manager implementations, from basic embedded loaders to complex systems with cryptographic verification and network capabilities.

5.1.2 Capability-based conditions

5.1.2.1 Introduction

The following conditions determine which security requirements apply to a specific boot manager. Each condition represents a technical capability that may be present in the product, regardless of how the product is deployed or configured. A boot manager may exhibit multiple conditions simultaneously, and the presence of any condition triggers all associated requirements.

Manufacturers shall identify all conditions applicable to their product in the Capability Assessment (Section 5.1.3). A capability is considered present if it can be activated through any means - default configuration, user configuration, firmware update, or undocumented interfaces.

These conditions are not mutually exclusive. A single boot manager typically exhibits one condition from each category, creating a capability profile that determines its applicable security requirements.

5.1.2.2 Boot architecture conditions

Boot architecture represents the fundamental security approach implemented by the boot manager. This is typically determined at design time and cannot be changed post-deployment.

#FIXME Add attested boot?

5.1.2.3 Update capability conditions

Update capability determines whether and how the boot manager can be modified after initial deployment. This affects vulnerability management and lifecycle security requirements.

- [UC-0]: No update capability - Boot manager code and configuration cannot be modified after manufacture (immutable).

5.1.2.4 Boot source conditions

Boot source conditions identify from which media types the boot manager can load and execute code. Each additional source increases attack surface and triggers specific security requirements.

- [BS-1]: Fixed media only - Boot exclusively from non-removable storage physically attached to the system (e.g., soldered SPI flash, eMMC, internal NVMe).

5.1.2.5 Configuration management conditions

Configuration capability determines whether boot behavior can be modified through settings, affecting both flexibility and attack surface.

- [CF-1]: Static configuration - Configuration can be set but requires physical access, special tools, or significant effort to modify (e.g., jumpers, one-time programming, or signed configuration blocks).

5.1.2.6 Hardware security conditions

Hardware security conditions indicate whether the boot manager utilizes dedicated security hardware for enhanced protection.

5.1.2.7 Recovery capability conditions

Recovery conditions determine how the system can recover from boot failures, corruption, or attacks.

5.1.3 Capability assessment

The manufacturer shall provide a Capability Assessment document that identifies all conditions from Section 5.1.2 applicable to their boot manager product. This document shall include:

- a) Product identification (name, version, unique identifier)
- b) Complete list of applicable conditions with justification
- c) Configuration options affecting conditions
- d) Mapping of triggered requirements
- e) Declaration of completeness

The Capability Assessment shall be maintained and updated when capabilities change through new versions, updates, or configuration changes.

5.1.4 Requirement structure and applicability

Requirements in clauses 5.2 through 5.13 follow the pattern established in this document:

- Requirements identified with unique identifiers (e.g., [SBD-BASE-RQ-1-01](#))
- Baseline requirements have “BASE” in their identifier and apply to all boot managers
- Conditional requirements specify their applicable conditions

Example patterns from this standard:

- [SBD-VERIFIED-RQ-1-07]: Applies when condition [BA-2](#) is present
- [SBD-UPDATE-OB-1-09]: Applies when conditions [UC-1](#), [UC-2](#), or [UC-3](#) are present
- [LOG-MEASURED-RQ-1-06]: Applies when condition [BA-3](#) is present

NOTE: Requirements using “OB” denote manufacturer obligations (processes, documentation) while “RQ” denotes technical product requirements. Both types may be baseline or conditional.

5.2 Security by design

5.2.1 General

This subclause addresses the CRA requirement that products with digital elements shall be designed, developed and produced in such a way that they ensure an appropriate level of cybersecurity based on the risks.

5.2.2 Secure by Design

5.2.2.1 General

A manufacturer of a boot manager shall implement secure by design principles throughout their lifecycle by applying the horizontal requirements established in [PT1 (General principles for cyber resilience)], with additional considerations specific to their role as the foundational trust component that establishes system security before any operating system or security services are available.

5.2.2.2 Input

- Applicable sections of [PT1 (General principles for cyber resilience)]
- Security Profile Assessment document identifying boot manager capabilities
- Boot architecture specifications (Basic, Measured, or Verified)
- Hardware security capabilities and constraints
- Threat model specific to boot manager deployment context

5.2.2.3 Requirements

[SBD-BASE-OB-1-01] The boot manager shall follow applicable requirements from [PT1 General principles for cyber resilience], including but not limited to: (i) risk assessment and treatment processes addressing boot-specific threats; (ii) security activities across all lifecycle stages from ROM development through end-of-life; (iii) secure development and implementation practices for constrained environments; and (iv) secure production practices preventing supply chain compromise.

[SBD-BASE-RQ-1-02] The boot manager shall be resistant to threats identified through threat modeling, specifically addressing: (i) pre-boot attacks attempting to bypass or compromise the boot process; (ii) persistent firmware implants and bootkits; (iii) physical attacks including fault injection and glitching; (iv) rollback attacks attempting to revert to vulnerable versions; (v) time-of-check-time-of-use vulnerabilities in the boot sequence; and (vi) supply chain attacks targeting boot components.

[SBD-BASE-OB-1-03] The manufacturer shall provide security architecture documentation that includes: (i) complete boot flow from power-on to OS handoff; (ii) trust boundaries between boot stages; (iii) cryptographic key hierarchy and storage; (iv) memory layout and protection mechanisms; (v) interfaces exposed at each boot stage; (vi) recovery and failsafe mechanisms; and (vii) sufficient information to understand the security architecture.

[SBD-BASE-RQ-1-04] The boot manager shall protect boot code against unauthorized modification through: (i) storage in write-protected or one-time-programmable memory where feasible; (ii) cryptographic integrity verification before execution; (iii) access controls preventing runtime modification; (iv) detection of tampering attempts; and (v) secure update mechanisms when updates are supported.

[SBD-BASE-RQ-1-05] The boot manager shall implement the principle of least privilege by: (i) executing each boot stage with minimum required privileges; (ii) dropping unnecessary capabilities before loading subsequent stages; (iii) isolating boot components from each other where possible; (iv) limiting access to cryptographic materials to only necessary components; and (v) preventing privilege escalation between boot stages.

[SBD-BASE-RQ-1-06] The boot manager shall fail securely on error conditions by: (i) halting the boot process when security verification fails; (ii) preventing execution of unverified code; (iii) clearing sensitive data from memory on

failure; (iv) entering a secure recovery mode rather than bypassing security; (v) generating tamper-evident logs of failure conditions; and (vi) preventing automated retry of failed security operations that could enable brute force attacks.

[SBD-VERIFIED-RQ-1-07] Applicable when Verified Boot capability [BA-2](#) is present. The boot manager shall support multiple certificate authorities enabling: (i) separation between vendor and owner certificates; (ii) owner-installable certificates for custom images; (iii) certificate revocation mechanisms including for the owner; (iv) hierarchical trust with root and intermediate certificates; (v) transition between certificate authorities during ownership changes; and (vi) certificate pinning.

[SBD-MEASURED-RQ-1-08] Applicable when Measured Boot capability [BA-3](#) is present. The boot manager shall implement measurement architecture that: (i) extends measurements in a deterministic order; (ii) includes all security-critical components and configuration; (iii) protects measurement logs from tampering; (iv) enables remote attestation where supported; and (v) documents the measurement process for validation.

[SBD-UPDATE-OB-1-09] Applicable when Update capability [UC-1](#), [UC-2](#), or [UC-3](#) is present. The manufacturer shall implement secure development practices for updates including: (i) automated security testing of all updates; (ii) staged rollout capabilities; (iii) protection mechanisms against unauthorized rollback; (iv) update signing by multiple parties where feasible; and (v) update transparency logs for audit.

[SBD-CONFIG-RQ-1-10] Applicable when Configuration capability [CF-1] or [CF-2](#) is present. The boot manager shall provide a secure configuration interface by: (i) authenticating all configuration access; (ii) validating configuration parameters before acceptance; and (iii) protecting stored configuration from tampering.

5.2.2.3 Output

- Evidence of [PT1 (General principles for cyber resilience)] compliance
- Boot-specific threat model documentation
- Security architecture documentation including trust boundaries and key management
- Code review and security testing evidence
- Risk assessment addressing identified threats
- Secure development lifecycle documentation

5.2.2.4 Assessment criteria

- Verification that all applicable [PT1] requirements are implemented and documented
- Confirmation that threat modelling addresses all boot-specific attack vectors
- Validation that security architecture enforces least privilege and defence in depth
- Testing evidence demonstrating fail-secure behaviour on all error paths
- Verification that boot code protection mechanisms prevent unauthorized modification
- Confirmation of support for multiple certificate authorities (when applicable)
- Evidence of secure development practices throughout the lifecycle
- Documentation completeness enabling third-party security assessment

NOTE: Assessment shall follow [PT1] procedures, supplemented by validation of boot-specific security considerations including pre-OS threat mitigation, hardware security integration, and chain of trust establishment.

5.3 Secure by Default Configuration

5.3.1 General

This subclause addresses the CRA requirement that products with digital elements shall be made available on the market with a secure by default configuration, including the possibility to reset the product to its original state.

For boot managers, “secure by default” means:

- All security features are enabled without user action
- No default passwords or known backdoors exist
- Only minimum necessary functionality is enabled
- Security cannot be accidentally weakened
- The default state provides maximum protection within the boot manager’s capabilities

5.3.2 Secure by default configuration

5.3.2.1 General

Boot managers represent the first code executed after power-on and establish the security foundation for all subsequent operations. These products are expected to ship with security controls properly configured and enabled from initial deployment to protect against attacks that may occur before any user configuration. The default configuration establishes the security baseline that many deployments, particularly in embedded and IoT devices, will operate with throughout the product lifecycle without modification.

5.3.2.2 Input

- Boot manager in factory default configuration state
- List of all boot manager capabilities and features
- Security features available in the implementation
- Default boot sources and boot order
- Network boot capabilities (if present)
- Debug interface status

5.3.2.3 Requirements

[DEFAULT-BASE-RQ-1-01] The boot manager shall enable all available security features by default unless their activation would prevent the system from booting. Where present, security features that shall be enabled, including: (i) cryptographic signature validation if available; (ii) measurement and logging capabilities if available; (iii) rollback protection if implemented; (iv) debug interface protection where interfaces can be controlled; (v) recovery mode authentication if recovery mode exists; and (vi) boot integrity checking if supported.

[DEFAULT-BASE-RQ-1-02] The boot manager shall not contain any default passwords, maintenance backdoors, or undocumented access methods. Any authentication mechanisms shall: (i) require credentials to be established during initial deployment; (ii) generate unique per-device credentials during manufacturing; or (iii) use cryptographic keys rather than passwords.

[DEFAULT-BASE-RQ-1-03] The boot manager shall disable all debug interfaces in production builds where technically feasible, including: (i) JTAG, SWD, and UART debug ports if present and controllable; (ii) diagnostic shell access if implemented; (iii) memory dump capabilities if available; (iv) verbose debug output; and (v) test modes if

present. Where debug capabilities cannot be disabled due to hardware limitations, they shall require authentication before activation or be documented as requiring physical security controls.

[DEFAULT-BASE-RQ-1-04] The boot manager shall configure only the minimum necessary boot sources required for its intended deployment. Where the boot manager supports multiple boot sources, it shall: (i) disable network boot if present and not required; (ii) restrict removable media boot if not essential; (iii) limit boot device search order to necessary devices; (iv) disable boot interruption keys where not required; and (v) prevent automatic fallback to less secure boot modes if multiple modes exist.

NOTE: Network boot is considered “required” only for devices specifically intended for network deployment (e.g., thin clients, diskless workstations). For devices with local storage, network boot should be disabled by default.

[DEFAULT-CONFIG-RQ-1-05] Applicable when Configuration capability [CF-1] or [CF-2](#) is present. Where boot managers support configuration changes, they shall: (i) preserve secure defaults when adding new configuration; (ii) require explicit action to weaken security settings; (iii) warn when security is being reduced; (iv) provide a mechanism to restore secure defaults; and (v) document the security impact of configuration changes.

[DEFAULT-CONFIG-RQ-1-06] Applicable when no Configuration capability [CF-0](#) is present. For boot managers with no user-configurable options (such as ROM-based or fully embedded implementations), the boot manager shall be built with security configuration that cannot be weakened, including: (i) no bypass mechanisms; (ii) no debug capabilities in production; and (iii) deterministic secure boot flow.

5.3.2.4 Output

- Boot manager configured with maximum security posture
- All unnecessary features and interfaces disabled
- No default credentials or backdoors present
- Network boot disabled (unless required)
- Security features active and enforced
- Configuration locked to secure defaults
- User documentation describing default security state

5.3.2.5 Assessment criteria

- Verification that all available security features are enabled by default
- Testing performed on factory-reset or first-boot state
- Confirmation that no default passwords or backdoors exist through analysis and testing
- Testing that unsigned code cannot execute when verification is available
- Validation that network boot is disabled unless explicitly required
- Verification that debug interfaces are disabled or require authentication
- Confirmation that boot sources are minimized to necessary options
- Testing that configuration changes require authentication
- Documentation review confirming secure defaults are clearly described
- Validation that network boot is disabled unless explicitly required

5.4 Access Control

5.4.1 General

This subclause addresses the CRA requirement that products with digital elements shall ensure protection from unauthorised access by appropriate control mechanisms, including but not limited to authentication, identity or access management systems, and report on possible unauthorised access.

5.4.2 Authentication and access control

5.4.2.1 General

Access control in boot managers serves as the critical security gate that determines which software can execute on the system. Boot managers control the system's most privileged transition - from hardware initialization to operating system execution - making their access control mechanisms fundamental to overall system security. Unlike application-level access control, boot manager access control are expected to operate in a pre-OS environment with minimal resources while establishing the trusted computing base upon which all subsequent security depends.

Boot managers implement access control through two primary mechanisms: code authorization and configuration protection. Code authorization determines which firmware components, bootloaders, and operating systems are permitted to execute. Configuration protection, where applicable, controls who can modify boot settings, security policies, and trusted key stores. Most boot managers have no concept of user accounts or interactive authentication; instead, they rely on cryptographic verification, physical presence detection, and hardware-based protections.

5.4.2.2 Input

- Boot components requiring verification (kernel, initrd, drivers)
- Digital signatures and certificates
- Trusted certificate stores and key databases
- Configuration interfaces (if present)
- Physical presence indicators
- Hardware security module state (if present)
- Previous boot security state

5.4.2.3 Requirements

[AUTH-BASE-RQ-1-01] Boot managers shall implement access control for boot component execution by verifying the authenticity and integrity of all code before execution. This shall be achieved through: (i) digital signature verification where cryptographic capabilities exist; (ii) hash-based integrity checking as a minimum; (iii) prevention of unsigned code execution in production configurations; (iv) clear identification of the trust anchor; and (v) protection of the verification mechanism from bypass.

[AUTH-BASE-RQ-1-02] Boot managers with cryptographic capabilities shall verify digital signatures of firmware and boot components using: (i) trusted certificates stored in protected storage; (ii) verification against a chain of trust rooted in hardware or immutable storage; (iii) rejection of components with invalid, expired, or revoked signatures; (iv) clear failure indication when signature verification fails; and (v) prevention of boot continuation with unverified components.

[AUTH-BASE-RQ-1-03] Boot managers shall protect their trust anchor through: (i) storage of root public keys and certificates in write-protected or one-time programmable memory where feasible; (ii) use of hardware security modules or trusted platform modules when available for private key operations; (iii) protection against unauthorized

modification of trusted certificate stores; (iv) separation between vendor keys and user-enrolled keys where both are supported; and (v) clear documentation of the trust model.

NOTE: Public keys for verification should be integrity-protected. Private keys, if stored by the boot manager (e.g., for attestation), shall be encrypted or stored in secure hardware.

[AUTH-BASE-RQ-1-04] Boot managers with configuration capabilities shall implement access control to prevent unauthorized modification of security policies by: (i) requiring physical presence for any changes to trusted keys or certificates; (ii) restricting modifications to secure boot policies; (iii) protecting boot order and boot parameters from unauthorized changes; (iv) implementing secure defaults that cannot be weakened without authentication; and (v) preventing runtime downgrades of security settings.

[AUTH-CONFIG-RQ-1-05] Applicable when Configuration capability [CF-1] or [CF-2](#) is present. Boot managers shall protect against brute force and bypass attacks through: (i) limiting authentication attempts where passwords are used; (ii) increasing delays between failed verification attempts; (iii) requiring physical intervention after repeated failures; (iv) preventing rollback to vulnerable versions; and (v) detecting and responding to glitch or fault injection attempts where feasible.

[AUTH-UPDATE-RQ-1-06] Applicable when Update capability [UC-1](#), [UC-2](#), or [UC-3](#) is present. For boot managers without runtime configuration (ROM-based or fixed-function), access control shall be enforced through: (i) compile-time inclusion of trusted keys that cannot be modified; (ii) hardware-based protection against firmware modification; (iii) documented physical security requirements; and (iv) tamper-evident packaging or sealing where appropriate.

[AUTH-NETWORK-RQ-1-07] Applicable when Network Boot capability [BS-3](#) is present. Secure boot configuration policies shall be digitally signed and verified, including: (i) the policy defining trusted keys and settings; (ii) protection against policy rollback; (iii) separate policies for different security domains where applicable; (iv) clear indication when running with modified policies; and (v) ability to restore default secure policy.

5.4.2.4 Output

- Boot authorization decisions (proceed/halt)
- Signature verification results
- Trust chain validation status
- Audit records or measurements
- Security policy enforcement status
- Authentication success/failure indication
- System security state for handoff to boot target

5.4.2.5 Assessment criteria

- Verification that only authorized code can execute during boot
- Testing that unsigned or incorrectly signed components are rejected
- Validation of certificate chain and trust anchor protection
- Confirmation that configuration changes require appropriate authentication
- Testing of brute force protection mechanisms
- Verification that audit/measurement capabilities function correctly
- Testing that bypass of signature verification is not possible
- Validation that security policies are properly enforced
- For fixed implementations: Verification that trust is properly embedded and protected
- Documentation review confirming the trust model and key management

5.5 Data Protection

5.5.1 General

This subclause addresses the CRA requirement that products with digital elements shall protect the confidentiality of stored, transmitted or otherwise processed data, personal or other, such as by encrypting relevant data at rest or in transit by state of the art mechanisms, and by using other technical means.

5.5.2 Confidentiality protection

5.5.2.1 General

Boot managers handle highly sensitive cryptographic materials and configuration data that, if compromised, could undermine the entire system's security. These include signing keys, encryption keys, passwords, certificates, and security policies. Unlike operating systems that can rely on file system encryption and memory protection, boot managers are expected to protect sensitive data in resource-constrained environments with limited cryptographic capabilities and persistent threats from physical access.

5.5.2.2 Input

- Cryptographic keys and certificates
- User credentials (if applicable)
- Configuration data and security policies
- Boot measurements and logs
- Temporary secrets during cryptographic operations
- Debug and diagnostic information
- Documentation of residual side-channel risks for the deployment environment

5.5.2.3 Requirements

[CRYPTO-BASE-RQ-1-01] Boot managers shall protect cryptographic keys and sensitive data through secure storage mechanisms appropriate to their architecture: (i) using hardware security modules or trusted platform modules where available; (ii) storing keys in one-time programmable fuses or write-protected memory where feasible; (iii) encrypting keys when stored in writable storage; (iv) implementing key derivation rather than storage where possible; and (v) separating keys by function and privilege level.

[CRYPTO-BASE-RQ-1-02] Boot managers shall clear sensitive data from memory after use by: (i) overwriting cryptographic keys immediately after operations complete; (ii) clearing password buffers after authentication; (iii) zeroing temporary calculation buffers; (iv) preventing sensitive data from being included in crash dumps or logs; and (v) clearing all sensitive data before handoff to the operating system.

[CRYPTO-BASE-RQ-1-03] Boot managers with configuration storage shall encrypt sensitive configuration data including: (i) user credentials if stored; (ii) network boot parameters containing authentication information; (iii) private keys for secure boot operations; (iv) recovery keys or passwords; and (v) any configuration that could reveal security posture.

[CRYPTO-BASE-RQ-1-04] Boot managers shall protect against side-channel attacks where feasible through: (i) constant-time cryptographic operations for signature verification; (ii) power analysis resistance in critical operations; (iii) timing attack mitigation in authentication checks; and (iv) cache attack resistance where shared resources exist.

NOTE: Complete elimination of side-channel vulnerabilities may not be feasible in all boot manager implementations. Manufacturers should document residual risks in the security architecture documentation (see Section 5.2).

[CRYPTO-BASE-RQ-1-05] Boot managers shall protect boot logs and diagnostic information by: (i) excluding cryptographic keys from all logs; (ii) sanitizing memory addresses and pointer values; (iii) masking partial key material

or authentication tokens; (iv) encrypting logs containing system configuration details where feasible; and (v) limiting verbose logging to debug builds only.

[CRYPTO-BASE-RQ-1-06] Boot managers shall enable security event indication by: (i) clearly indicating when unsigned code is executed; (ii) warning before disabling secure boot; (iii) displaying certificate information during verification failures; (iv) providing tamper-evident indication of configuration changes; and (v) maintaining security event indicators accessible to the operating system.

NOTE: This requirement addresses indication of events to the owner/administrator. Detailed logging requirements are in Section 5.11.

[CRYPTO-BASE-RQ-1-07] Boot managers that support secure disposal shall provide mechanisms to: (i) cryptographically erase all sensitive data; (ii) clear all user-enrolled keys and certificates; (iii) reset security counters and anti-rollback protections; (iv) overwrite configuration storage multiple times where feasible; and (v) provide confirmation that sanitization completed successfully.

NOTE: This addresses owner data removal (e.g., for device transfer or disposal). Vendor keys and core boot functionality should remain intact to allow device reuse.

[CRYPTO-BASE-RQ-1-08] Boot managers shall protect sensitive data during transmission by: (i) encrypting network boot credentials when transmitted; (ii) using secure protocols for remote attestation where supported; (iii) protecting key exchange operations; (iv) clearing network buffers containing sensitive data after use; and (v) preventing sensitive data leakage in error messages or logs.

[CRYPTO-VERIFIED-RQ-1-09] Applicable when Verified Boot capability [BA-2](#) is present. The boot manager shall protect signature verification keys by (i) storing public keys separately from private keys; (ii) using hardware-backed key storage where available; (iii) implementing key hierarchy with root keys in most protected storage; (iv) supporting owner-initiated key revocation without exposing key material; and (v) preventing key extraction through debug interfaces.

[CRYPTO-UPDATE-RQ-1-10] Applicable when Update capability [UC-1](#), [UC-2](#), or [UC-3](#) is present. The boot manager shall protect update cryptographic operations by (i) using different keys for update verification than runtime verification; (ii) implementing perfect forward secrecy where feasible; (iii) clearing old keys after successful update; (iv) protecting rollback prevention counters; and (v) ensuring failed updates don't expose key material.

NOTE: Configuration systems shall distinguish between user data and system configuration, allowing selective erasure of user data while maintaining device function.

NOTE: Data protection requirements distinguish between:

- Confidentiality protection (encryption): Required for private keys, passwords, and sensitive configuration
- Integrity protection (signatures/MAC): Required for public keys, certificates, and security policies
- Both: Required for particularly sensitive data like attestation keys

5.5.2.4 Output

- Protected storage of all cryptographic materials
- Clear indication of security state
- Sanitized logs free of sensitive data
- Security event notifications
- Confirmation of secure erasure (when requested)
- Protected configuration data

5.5.2.5 Assessment criteria

- Verification that cryptographic keys are properly protected in storage
- Testing that sensitive data is cleared from memory after use

- Confirmation that logs do not contain sensitive information
- Validation of encryption for sensitive configuration data
- Testing of side-channel attack resistance where implemented
- Verification that unsigned code execution triggers visible warnings
- Testing secure erasure mechanisms where provided
- Analysis of key hierarchy and separation
- Verification that debug builds are clearly distinguished from production
- Documentation review of residual risks and compensating controls

5.6 Integrity Protection

5.6.1 General

This subclause addresses the CRA requirement that products with digital elements shall protect the integrity of stored, transmitted or otherwise processed data, personal or other, commands, programs and configuration against any manipulation or modification not authorised by the user, and report on corruptions.

Boot managers implement integrity protection through three complementary approaches:

- Verification: Cryptographically verify components before execution (fail if invalid)
- Measurement: Record component state for later attestation (boot continues regardless)
- Protection: Prevent unauthorized modification of boot components and configuration

Requirements apply based on the boot manager's implemented capabilities.

5.6.2 Boot chain integrity

5.6.2.1 General

Integrity protection forms the fundamental security property of boot managers, ensuring that only authorized and unmodified code executes during the critical transition from power-on to operating system. Boot managers are expected to establish and maintain a chain of trust where each component verifies the next before transferring control. This verification need to resist sophisticated attacks including component substitution, rollback attempts, and time-of-check-time-of-use exploits.

5.6.2.2 Input

- Boot components requiring verification
- Cryptographic signatures and hashes
- Version information and rollback counters
- Configuration data and security policies
- Hardware security capabilities (TPM/HSM if present)
- Update packages and patches

5.6.2.3 Requirements

[INTEGRITY-BASE-RQ-1-01] Boot managers shall verify the integrity of all boot components before execution through: (i) cryptographic signature verification where capabilities exist; (ii) hash comparison against known-good values as minimum protection; (iii) verification of the entire boot chain from initial boot code to boot target handoff; (iv) clear failure indication when verification fails; and (v) prevention of boot continuation with unverified components.

[INTEGRITY-BASE-RQ-1-02] Boot managers shall implement anti-rollback protection to prevent unauthorized installation of older, potentially vulnerable versions through: (i) monotonic counters that increment with each update; (ii) version checking against minimum acceptable versions; (iii) hardware-backed counters where available; (iv) tamper-evident storage of version information; and (v) rejection of components with lower version numbers than currently installed.

[INTEGRITY-BASE-RQ-1-03] Boot managers shall protect configuration data integrity by: (i) computing and verifying checksums or hashes of configuration; (ii) detecting unauthorized modifications to security policies; (iii) using authenticated encryption for sensitive settings where feasible; (iv) implementing tamper detection for security-critical parameters; and (v) restoring secure defaults when corruption is detected.

[INTEGRITY-BASE-RQ-1-04] Boot managers shall detect and respond to component substitution attempts through: (i) binding components to specific hardware where feasible; (ii) detecting unexpected changes in component measurements; (iii) verifying component provenance through certificates; (iv) checking component compatibility and version consistency; and (v) halting boot when substitution is detected.

[INTEGRITY-BASE-RQ-1-05] Boot managers shall protect against time-of-check-time-of-use (TOCTOU) attacks by: (i) minimizing the window between verification and execution; (ii) loading components into protected memory before verification; (iii) preventing modification of verified components before execution; (iv) re-verifying components if delays occur; and (v) using atomic operations where possible.

[INTEGRITY-BASE-RQ-1-06] Boot managers shall implement cryptographic integrity protection using: (i) approved cryptographic algorithms with adequate security strength; (ii) minimum RSA key size of 2048 bits or ECC key size of 256 bits; (iii) SHA-256 or stronger for hash functions; (iv) regular algorithm review and upgrade paths; and (v) preparation for post-quantum cryptography migration where feasible.

#FIXME Approved cryptographic algorithms in vertical standards is wider discussion, suggestion: “security strength that matches latest applicable regulations or recommendations from security authorities”

[INTEGRITY-BASE-RQ-1-07] Boot managers without hardware security component support shall implement alternative integrity protection through: (i) software-based verification using protected storage; (ii) redundant verification using multiple methods; (iii) environmental assumptions documented for physical security; (iv) tamper-evident mechanisms where feasible; and (v) compensating controls appropriate to the deployment model.

[INTEGRITY-UPDATE-RQ-1-08] Applicable when Update capability [UC-1](#), [UC-2](#), or [UC-3](#) is present. Update packages shall be verified for integrity through: (i) signature verification before installation; (ii) complete package hash verification; (iii) individual component verification within packages; (iv) unauthorized rollback protection enforcement during updates; and (v) atomic update operations preventing partial installations.

[INTEGRITY-MEASURED-RQ-1-09] Applicable when Measured Boot capability [BA-3](#) is present. The boot manager shall extend integrity measurements by: (i) measuring each component before execution; (ii) extending measurements into PCRs or equivalent registers; (iii) including configuration and policy in measurements; (iv) providing measurement logs for attestation; and (v) protecting measurement integrity from tampering.

[INTEGRITY-VERIFIED-RQ-1-10] Applicable when Verified Boot capability [BA-2](#) is present. The boot manager shall enforce strict verification by: (i) maintaining a whitelist of approved signatures, where feasible owner-configurable; (ii) checking certificate validity and revocation; (iii) verifying the entire certificate chain; (iv) supporting multiple signature formats where required; and (v) providing bypass only through authenticated physical presence.

[INTEGRITY-VERIFIED-RQ-1-11] Applicable when Verified Boot capability [BA-2](#) is present. The boot manager shall use Key Exchange Key (KEK) lists or equivalent mechanisms to store public keys from trusted certificate authorities, where: (i) only boot components signed with these trusted certificates are allowed to load; (ii) the KEK database is protected from unauthorized modification; (iii) updates to the KEK require higher privilege than normal configuration; (iv) compromised keys can be revoked through dbx or equivalent mechanisms; and (v) the chain of trust is documented and auditable.

5.6.2.4 Output

- Verification results for each boot component

- Chain of trust validation status
- Anti-rollback counter values
- Configuration integrity status
- Detection alerts for substitution attempts
- Measurement logs (where applicable)
- Clear indication of boot security state

5.6.2.5 Assessment criteria

- Verification that all components are checked before execution
- Testing that modified components are detected and rejected
- Validation of anti-rollback protection preventing downgrades
- Confirmation that configuration tampering is detected
- Testing of TOCTOU attack resistance
- Verification of cryptographic algorithm compliance
- Key size validation meeting minimum requirements
- Testing of TPM/HSM integration where present
- For non-TPM systems: Validation of alternative protection mechanisms
- Documentation review of post-quantum migration strategy
- Testing that component substitution is detected and prevented
- Verification that update integrity is maintained

5.7 Data Minimization

5.7.1 General

This subclause addresses the CRA requirement that products with digital elements shall process only data, personal or other, that are adequate, relevant and limited to what is necessary in relation to the intended purpose of the product with digital elements (data minimisation).

5.7.2 Minimal data processing

5.7.2.1 General

Boot managers operate in a unique context where data minimization is both a security requirement and an operational necessity. Due to severe memory constraints, limited storage, and the critical nature of the boot process, boot managers must inherently minimize data collection and processing. Nevertheless boot managers should process only the absolute minimum data required to establish a secure boot chain and hand off control to the next stage.

5.7.2.2 Input

- Boot configuration parameters
- Hardware initialization data

- Security measurements and logs
- Error conditions and diagnostic states
- User interaction (if any)

5.7.2.3 Requirements

[MINIMAL-BASE-RQ-1-01] Boot managers shall process only the minimum data necessary for boot operations, limited to: (i) essential hardware initialization parameters; (ii) boot device identification and selection; (iii) security verification data for boot components; (iv) minimal error indicators for boot failures; and (v) required measurements for attestation where applicable.

[MINIMAL-BASE-RQ-1-02] Boot managers shall limit diagnostic data collection to essential security and failure information by: (i) disabling verbose logging in production builds; (ii) excluding memory dumps unless explicitly required for security; (iii) collecting only boot stage success/failure indicators; (iv) avoiding collection of user behavior or usage patterns; (v) limiting error messages to prevent information disclosure; and (vi) clearly distinguishing production from debug builds.

NOTE: Debug builds may collect additional data but shall not be shipped as production firmware.

[MINIMAL-BASE-RQ-1-03] Boot managers shall minimize data retention by: (i) not persisting data beyond what is required for the current boot cycle; (ii) clearing temporary data from memory after use; (iii) limiting log retention to essential security events only; (iv) avoiding creation of diagnostic files unless critical failures occur; and (v) ensuring any retained data is cleared on successful boot completion.

[MINIMAL-BASE-RQ-1-04] Boot managers shall exclude unnecessary data from any output or logs including: (i) system memory contents beyond boot-relevant regions; (ii) detailed hardware configuration beyond boot requirements; (iii) network parameters not essential for network boot; (iv) user data from previous OS sessions; and (v) detailed timing information that could aid side-channel attacks.

[MINIMAL-BASE-RQ-1-05] For boot managers with no persistent storage, data collection shall be limited to: (i) transient error flags in registers; (ii) minimal status indicators for the OS; (iii) measurements in volatile PCRs where applicable; and (iv) essential state for boot completion only.

[MINIMAL-MEASURED-RQ-1-06] Applicable when Measured Boot capability [BA-3](#) is present. Measurements shall be limited to: (i) security-critical components only; (ii) configuration affecting security posture; (iii) aggregated hashes rather than raw data; (iv) standardized PCR allocations; and (v) minimal log entries for attestation.

[MINIMAL-NETWORK-RQ-1-07] Applicable when Network Boot capability [BS-3](#) is present. Network operations shall minimize data exposure by: (i) requesting only required boot files; (ii) avoiding broadcast of system information; (iii) limiting protocol negotiations to essential parameters; (iv) not retaining network credentials beyond use; and (v) clearing network buffers after boot; (vi) using minimal device identification; and (vii) avoiding unique persistent identifiers where possible.

[MINIMAL-CONFIG-RQ-1-08] Applicable when Configuration capability [CF-1] or [CF-2](#) is present. Configuration storage shall be minimized to: (i) essential boot parameters only; (ii) security policy settings; (iii) boot device priorities; (iv) minimal user preferences affecting boot; and (v) no collection of usage statistics or telemetry.

5.7.2.4 Output

- Minimal boot status information
- Essential error indicators only
- Limited security measurements (where applicable)
- No persistent diagnostic data unless critical failure
- Clear memory state for boot target handoff

5.7.2.5 Assessment criteria

- Verification that only essential data is processed during boot

- Confirmation that diagnostic data collection is minimized in production
- Testing that temporary data is cleared after use
- Validation that logs contain only necessary security information
- Verification that no user data or telemetry is collected
- Testing that network operations don't leak system information
- Confirmation that memory is cleared of sensitive data before boot target handoff
- Review of any persistent storage to confirm minimal retention
- Documentation review confirming data minimization principles

5.8 Availability and Resilience

5.8.1 General

This subclause addresses the CRA requirement that products with digital elements shall protect the availability of essential and basic functions, also after an incident, including through resilience and mitigation measures against denial-of-service attacks.

5.8.2 Recovery and fault tolerance

5.8.2.1 General

Boot managers must maintain system availability even when facing failures, attacks, or corruption. Unlike applications that can be restarted, a boot manager failure can render the entire system inoperable. Boot managers must therefore implement multiple layers of resilience, from automatic recovery mechanisms to failsafe operations that ensure the system can either boot successfully or enter a recoverable state.

5.8.2.2 Input

- Update failure conditions
- Corrupted boot components
- Hardware faults or anomalies
- Attack attempts (glitching, fault injection)
- Power interruptions
- Invalid or malicious boot configurations

5.8.2.3 Requirements

[AVAIL-BASE-RQ-1-01] Boot managers shall implement recovery mechanisms to maintain availability after failures through: (i) fallback to previous known-good configuration; (ii) redundant boot paths where feasible; (iii) automatic recovery from corrupted settings; (iv) boot retry with degraded functionality if necessary; and (v) clear indication of recovery mode activation.

NOTE: Recovery mechanisms must be designed to prevent an attacker from deliberately triggering recovery to bypass security.

[AVAIL-BASE-RQ-1-02] Boot managers shall prevent bypass of the boot sequence by: (i) disabling boot interruption in production unless required; (ii) authenticating any boot flow modifications; (iii) preventing skip of security

verification steps; (iv) detecting and responding to glitch attacks; and (v) maintaining boot integrity even under fault conditions.

[AVAIL-BASE-RQ-1-03] Boot managers shall implement failsafe operation ensuring: (i) the system fails to a secure state when normal boot cannot proceed; (ii) sensitive operations are not attempted with degraded security; (iii) recovery mode requires authentication or physical presence; (iv) partial boot is prevented when security components fail; and (v) clear error indication guides recovery actions.

[AVAIL-BASE-RQ-1-04] Boot managers shall protect against denial-of-service conditions by: (i) implementing timeouts for all operations; (ii) limiting retry attempts for failed operations; (iii) preventing infinite loops in boot logic; (iv) detecting and mitigating fault injection attempts; and (v) maintaining minimal functionality for recovery even under attack.

[AVAIL-BASE-RQ-1-05] Boot managers shall implement fault tolerance through: (i) error detection and correction for critical data where feasible; (ii) redundant storage of essential boot code; (iii) checksum verification of critical structures; (iv) graceful handling of hardware anomalies; and (v) progressive boot attempts with increasing compatibility.

[AVAIL-UPDATE-RQ-1-06] Applicable when Update capability [UC-1](#), [UC-2](#), or [UC-3](#) is present. Boot managers shall ensure recovery from update failures by: (i) maintaining backup of previous version; (ii) automatic rollback on update failure; (iii) verification before committing updates; (iv) atomic update operations preventing partial updates; and (v) recovery mode accessible even with corrupted primary image.

[AVAIL-UPDATE-RQ-1-07] Applicable when Update capability [UC-1](#), [UC-2](#), or [UC-3](#) is present. The boot manager shall implement A/B update schemes or equivalent mechanisms where feasible to: (i) maintain a working boot image during updates; (ii) enable seamless authorized rollback; (iii) verify new image before switching; (iv) preserve recovery capability; and (v) indicate which image is active.

[AVAIL-HARDWARE-RQ-1-08] Applicable when Hardware Security capability [HS-1](#) or [HS-2](#) is present. Hardware-assisted recovery shall include: (i) hardware watchdog timer to detect hangs; (ii) automatic reset on security violations; (iii) tamper-triggered recovery mode; (iv) hardware-enforced boot retry limits; and (v) failover to hardware-protected recovery image.

[AVAIL-NETWORK-RQ-1-09] Applicable when Network Boot capability [BS-3](#) is present. Network boot resilience shall include: (i) timeout and fallback to local boot; (ii) retry with exponential backoff; (iii) multiple server options where feasible; (iv) graceful handling of network failures; and (v) prevention of network-based DoS affecting local boot.

5.8.2.4 Output

- System successfully booted or in recoverable state
- Clear indication of recovery mode or degraded boot
- Preserved security posture even in failure cases
- Audit log of failure and recovery attempts
- Guidance for manual recovery if automatic recovery fails

5.8.2.5 Assessment criteria

- Testing of recovery mechanisms under various failure conditions
- Verification that boot sequence cannot be bypassed
- Validation of failsafe operation maintaining security
- Testing of DoS resistance including fault injection
- Verification of update failure recovery (where applicable)
- Confirmation that redundant boot paths function correctly
- Testing that partial or incomplete boots are prevented

- Validation of timeout and retry mechanisms
- Testing of graceful degradation scenarios
- Documentation review of recovery procedures

5.9 Impact Minimization

5.9.1 General

This subclause addresses the CRA requirement that products with digital elements shall minimise the negative impact by the products themselves or connected devices on the availability of services provided by other devices or networks.

For boot managers, impact minimization primarily concerns:

- Network behavior during network boot operations
- Resource consumption in shared environments (virtualization, multi-tenant)
- Hardware resource usage that affects subsequent OS operation
- Failure modes that could affect connected systems

5.9.2 System impact minimization

5.9.2.1 General

Boot managers must minimize their impact on other system components and connected devices. While boot managers operate primarily during system initialization, their actions can affect subsequent system operation, connected peripherals, and even network resources. A malfunctioning or compromised boot manager must not cascade failures to other systems or consume resources that prevent normal operation of other devices.

5.9.2.2 Input

- System resource availability (memory, CPU, buses)
- Connected devices and peripherals
- Network resources (if network boot capable)
- Shared hardware resources
- Power management states

5.9.2.3 Requirements

[IMPACT-BASE-RQ-1-01] Boot managers shall minimize resource consumption by: (i) releasing hardware resources promptly after use; (ii) avoiding unnecessary polling or busy-waiting; (iii) limiting memory usage to essential operations; (iv) freeing allocated resources before boot target handoff; and (v) preventing resource exhaustion that could affect the OS or other devices.

[IMPACT-BASE-RQ-1-02] Boot managers shall prevent negative impacts on connected devices through: (i) proper initialization without disrupting attached peripherals; (ii) avoiding unnecessary resets of connected hardware; (iii)

maintaining stable power states for peripherals; (iv) preventing bus flooding or excessive communication; and (v) graceful handling of device errors without cascading failures.

[IMPACT-BASE-RQ-1-03] Boot managers shall minimize boot time impact by: (i) implementing efficient boot flows; (ii) parallelizing operations where safe; (iii) avoiding unnecessary delays or timeouts; (iv) optimizing verification operations; and (v) providing fast-boot options where security permits.

[IMPACT-BASE-RQ-1-04] Boot managers shall prevent propagation of failures by: (i) containing errors within the boot domain; (ii) preventing corrupted states from affecting the OS; (iii) isolating security violations; (iv) avoiding actions that could damage hardware; and (v) ensuring clean handoff even after partial failures.

[IMPACT-BASE-RQ-1-05] Boot managers shall implement proper cleanup before boot target handoff including: (i) clearing temporary data structures; (ii) releasing all claimed resources; (iii) resetting hardware to expected states; (iv) disabling boot-specific configurations; and (v) ensuring the boot target receives a clean system state.

[IMPACT-NETWORK-RQ-1-06] Applicable when Network Boot capability [BS-3](#) is present. Network boot shall minimize network impact by: (i) avoiding broadcast storms or excessive retries; (ii) implementing proper backoff algorithms; (iii) limiting bandwidth consumption; (iv) preventing network loops or floods; and (v) gracefully handling network congestion.

[IMPACT-UPDATE-RQ-1-07] Applicable when Update capability [UC-1](#), [UC-2](#), or [UC-3](#) is present. Update operations shall minimize system impact through: (i) performing updates without affecting other system operations where feasible; (ii) avoiding excessive flash wear through unnecessary writes; (iii) scheduling updates to minimize disruption; (iv) preventing update failures from affecting other components; and (v) maintaining system responsiveness during updates.

[IMPACT-HARDWARE-RQ-1-08] Applicable when Hardware Security capability [HS-1](#) or [HS-2](#) is present. Security operations shall minimize performance impact by: (i) optimizing cryptographic operations; (ii) using hardware acceleration where available; (iii) caching verification results when safe; (iv) avoiding redundant security checks; and (v) balancing security with boot performance.

5.9.2.4 Output

- Clean system state for boot target handoff
- Released resources and cleared memory
- Stable peripheral and device states
- Minimal boot time within security constraints
- No lingering effects from boot process

5.9.2.5 Assessment criteria

- Measurement of resource consumption during boot
- Verification that resources are properly released
- Testing that connected devices remain functional
- Validation that failures don't cascade to other components
- Network impact assessment (where applicable)
- Boot time optimization within security requirements
- Verification of clean boot target handoff
- Testing that peripheral devices aren't disrupted
- Confirmation that no resources remain claimed after boot

5.10 Attack Surface Minimization

5.10.1 General

This subclause addresses the CRA requirement that products with digital elements shall be designed, developed and produced to limit attack surfaces, including external interfaces.

5.10.2 Attack surface reduction

5.10.2.1 General

Boot managers operate at the highest privilege level with direct hardware access, making attack surface minimization critical. Every unnecessary feature, interface, or code path represents a potential vulnerability that could compromise the entire system. Boot managers must implement the principle of minimal functionality - including only what is essential for secure boot operations while eliminating all unnecessary capabilities that could be exploited.

5.10.2.2 Input

- List of boot manager features and capabilities
- Debug and diagnostic interfaces
- Network protocols and services (if any)
- Development and test code
- Hardware interfaces and ports
- Optional functionality

5.10.2.3 Requirements

[SURFACE-BASE-RQ-1-01] Boot managers shall include only functionality essential for boot operations by: (i) removing all unused code paths and features; (ii) eliminating optional capabilities not required for the deployment; (iii) excluding diagnostic functions from production builds; (iv) removing compatibility code for unsupported hardware; and (v) minimizing the code base to essential operations only.

[SURFACE-BASE-RQ-1-02] Boot managers shall disable all debug interfaces in production including: (i) hardware debug ports (JTAG, SWD, UART) through disabling or physical removal; (ii) software debug shells and monitors; (iii) memory dump and examination functions; (iv) verbose logging and trace capabilities; and (v) any backdoor or maintenance interfaces.

[SURFACE-BASE-RQ-1-03] Boot managers shall eliminate all development and test code from production builds by: (i) using build-time flags to exclude test code; (ii) removing debugging assertions and checks; (iii) eliminating code coverage instrumentation; (iv) excluding unit test harnesses; and (v) removing any experimental or deprecated features.

[SURFACE-BASE-RQ-1-04] Boot managers shall protect against fault injection attacks where feasible through: (i) implementing redundant security checks; (ii) using error detection on critical operations; (iii) randomizing timing where possible; (iv) detecting glitch attempts through anomaly detection; and (v) failing securely when faults are detected.

[SURFACE-BASE-RQ-1-05] Boot managers shall minimize external interfaces by: (i) disabling unused hardware interfaces; (ii) limiting active ports to those required for boot; (iii) implementing strict input validation; (iv) rejecting malformed or oversized inputs; and (v) timing out on incomplete operations.

[SURFACE-BASE-RQ-1-06] Boot managers shall implement defence in depth by: (i) validating all inputs regardless of source; (ii) implementing bounds checking on all operations; (iii) using safe programming practices; (iv) avoiding dynamic memory allocation where possible; and (v) failing closed on any security-relevant errors.

[SURFACE-NETWORK-RQ-1-07] Applicable when Network Boot capability [BS-3](#) is present. Network protocols shall be limited to: (i) only essential protocols for boot (DHCP, TFTP, or HTTPS); (ii) disabled management protocols;

(iii) no unnecessary service discovery (mDNS, SSDP, etc.); (iv) minimal protocol implementations; (v) strict protocol conformance checking; (vi) disabled IPv6 if not required; and (vii) no legacy protocols (rsh, NFSv2, etc.).

[SURFACE-CONFIG-RQ-1-08] Applicable when Configuration capability [CF-1] or [CF-2](#) is present. Configuration interfaces shall be minimized by: (i) limiting configurable options to essential parameters; (ii) clearly separating advanced or dangerous options requiring additional authentication; (iii) disabling remote configuration unless required; (iv) implementing read-only access by default; (v) requiring authentication for access and any changes; and (vi) documenting security impact of each configuration option.

NOTE: “Security-critical options” include: disabling secure boot, enrolling new keys, changing trust anchors, enabling debug modes, or any setting that weakens the security posture.

[SURFACE-UPDATE-RQ-1-09] Applicable when Update capability [UC-1](#), [UC-2](#), or [UC-3](#) is present. Update interfaces shall be restricted through: (i) accepting updates only from authenticated sources, including the owner; (ii) limiting update protocols to secure options; (iii) removing update capability if updates aren’t supported; and (iv) isolating update logic from normal boot path.

5.10.2.4 Output

- Minimal boot manager with only essential functionality
- All debug interfaces disabled or removed
- No development or test code in production
- Reduced external interface exposure
- Hardened against fault injection
- Clear documentation of remaining attack surface

5.10.2.5 Assessment criteria

- Code review confirming removal of unnecessary functionality
- Verification that debug interfaces are disabled in production
- Testing that development/test code is excluded from builds
- Validation of fault injection protections where implemented
- Network protocol analysis showing minimal implementation
- Interface enumeration confirming only essential ports active
- Binary analysis confirming no backdoors or hidden features
- Input fuzzing to verify robust input validation
- Documentation review of security architecture and remaining risks

5.11 Monitoring and Logging

5.11.1 General

This subclause addresses the CRA requirement that products with digital elements shall provide security related information by recording and monitoring relevant internal activity, including the access to or modification of data, services or functions.

5.11.1 General

This subclause addresses the CRA requirement for monitoring and logging of security events.

5.11.2 Boot event logging

5.11.2.1 General

Boot managers must provide visibility into the boot process for security monitoring, attestation, and forensic analysis. However, logging in boot managers faces unique constraints: limited or no persistent storage, pre-OS environment without file systems, and severe memory limitations. Boot managers must therefore implement logging mechanisms appropriate to their architecture while ensuring log integrity and availability to the operating system or management systems.

5.11.2.2 Input

- Boot events and security decisions
- Component verification results
- Configuration changes
- Error conditions and failures
- Security policy violations
- Timestamp sources (if available)

5.11.2.3 Requirements

[LOG-BASE-RQ-1-01] Boot managers shall log security-relevant events to the extent possible within their architecture, including: (i) boot stage progression and completion; (ii) component verification success or failure; (iii) security policy violations; (iv) recovery mode activation; (v) configuration changes if applicable; (vi) authentication attempts and outcomes; (vii) certificate validation results; and (viii) any security exception or bypass events.

NOTE: “Security-relevant” means any event that affects the security posture or could indicate attempted compromise.

[LOG-BASE-RQ-1-02] Boot managers shall protect log integrity through mechanisms appropriate to their capabilities: (i) using write-once storage where available; (ii) implementing append-only log structures; (iii) computing cryptographic hashes of log entries; (iv) preventing log tampering or deletion; and (v) detecting log corruption or rollback attempts.

[LOG-BASE-RQ-1-03] Boot managers shall make logs available to the operating system or management systems through: (i) passing log buffer addresses to the OS; (ii) storing logs in standardized locations; (iii) implementing log export protocols where applicable; (iv) preserving logs across warm reboots; and (v) providing APIs for log retrieval where feasible.

[LOG-BASE-RQ-1-04] Boot managers shall implement timestamp mechanisms appropriate to their environment: (i) using hardware real-time clock where available; (ii) implementing monotonic counters as minimum; (iii) recording relative timestamps if absolute time unavailable; (iv) maintaining timestamp consistency across boot stages; and (v) indicating timestamp source and reliability.

[LOG-BASE-RQ-1-05] Boot managers with limited storage shall prioritize security-critical events by: (i) maintaining only essential security events; (ii) using circular buffers with newest events preserved; (iii) aggregating repeated events; (iv) storing event codes rather than verbose messages; and (v) ensuring critical security violations are never overwritten.

[LOG-BASE-RQ-1-06] Boot managers shall maintain audit capabilities appropriate to their architecture by: (i) recording successful and failed verification attempts in persistent storage where available; (ii) extending platform configuration registers with boot events in systems with hardware security components; (iii) maintaining tamper-evident logs of security policy changes; (iv) providing attestation capabilities for remote verification where supported; and (v) indicating security state through available mechanisms even without persistent storage.

[LOG-MEASURED-RQ-1-07] Applicable when Measured Boot capability [BA-3](#) is present. The boot manager shall support attestation by: (i) platform configuration registers or equivalent secure storage; (ii) maintaining an event log

correlating register extensions; (iii) providing standardized log formats (TCG or equivalent); (iv) enabling remote attestation protocols; and (v) protecting attestation data from tampering.

[LOG-MEASURED-RQ-1-08] Applicable when Measured Boot capability [BA-3](#) is present. Measurement logs shall include: (i) component hashes and PCR indices; (ii) event types and descriptions; (iii) version information for measured components; (iv) configuration values affecting security; and (v) sufficient detail for attestation verification.

[LOG-NETWORK-RQ-1-09] Applicable when Network Boot capability [BS-3](#) is present. Network boot events shall be logged including: (i) server connections and authentication; (ii) downloaded component identities; (iii) verification results for network-loaded images; (iv) network failures and retries; and (v) fallback to local boot if applicable.

[LOG-UPDATE-RQ-1-10] Applicable when Update capability [UC-1](#), [UC-2](#), or [UC-3](#) is present. Update events shall be logged including: (i) update initiation and source; (ii) version transitions; (iii) verification results; (iv) rollback events; and (v) update failures and recovery actions.

5.11.2.4 Output

- Boot event log accessible to OS
- Integrity-protected log entries
- Attestation data (where applicable)
- Timestamps or sequence indicators
- Clear indication of security-relevant events
- Standardized log formats where feasible

5.11.2.5 Assessment criteria

- Verification that security-relevant events are logged
- Testing of log integrity protection mechanisms
- Validation that logs are accessible to OS or management systems
- Confirmation of timestamp accuracy and consistency
- Testing of attestation capabilities (where applicable)
- Verification that logs survive warm reboots
- Testing that critical events are preserved even with limited storage
- Validation of standardized log format compliance
- Review of log completeness for security monitoring

5.12 Vulnerability Management

5.12.1 General

This subclause addresses the CRA requirement that products with digital elements shall ensure that vulnerabilities can be addressed through security updates, including mechanisms for secure distribution and installation of updates throughout the product lifecycle.

5.12.2 Vulnerability handling

5.12.2.1 General

Boot managers present unique challenges for vulnerability management. Many boot managers cannot be updated after deployment (ROM-based, OTP), while others require special procedures to update safely without bricking the device. The critical nature of boot managers means that update failures can render systems completely inoperable, requiring physical intervention. Vulnerability management must therefore balance security needs with the risk of failed updates and consider the limitations of different boot manager architectures.

5.12.2.2 Input

- Vulnerability reports and security advisories
- Update packages from manufacturer
- Current version and security state
- Hardware update capabilities
- Rollback protection state

5.12.2.3 Requirements

[VULN-BASE-RQ-1-01] Boot managers that support updates shall implement authenticated update mechanisms ensuring: (i) cryptographic verification of update authenticity; (ii) verification against manufacturer or owner-authorized keys; (iii) integrity checking of update packages; (iv) rejection of unauthorized or tampered updates; and (v) secure channels for update delivery where feasible.

[VULN-BASE-RQ-1-02] Boot managers shall implement update notification mechanisms appropriate to their architecture: (i) status indicators for available updates where interfaces exist; (ii) version information accessible to OS or management systems; (iii) security advisory integration where feasible; (iv) update availability checks if network capable; and (v) clear documentation of update procedures.

[VULN-BASE-OB-1-03] Manufacturers shall provide vulnerability disclosure including: (i) clear identification of affected boot manager versions; (ii) impact assessment and severity ratings; (iii) mitigation measures where updates aren't possible; (iv) coordinated disclosure following industry practices; (v) security advisory publication for critical vulnerabilities; and (vi) clear indication of which products can/cannot be updated.

[VULN-BASE-RQ-1-04] Boot managers shall support end-of-life procedures by: (i) clear communication of support lifecycle; (ii) final security updates before end-of-support; (iii) documentation of residual risks; (iv) migration paths where applicable; and (v) secure decommissioning guidance.

[VULN-IMMUTABLE-OB-1-05] Applicable when no Update capability [UC-0] is present. For boot managers that cannot be updated (ROM, OTP, or hardware-limited), manufacturers shall: (i) document this limitation clearly; (ii) implement maximum security in initial release; (iii) provide detailed compensating controls guidance; (iv) maintain vulnerability monitoring and disclosure throughout product lifetime; and (v) specify hardware replacement as the update mechanism; (vi) implement defense-in-depth to reduce vulnerability impact; and (vii) provide clear end-of-life guidance when vulnerabilities cannot be mitigated.

NOTE: Inability to update does not exempt manufacturers from vulnerability management obligations. It increases the obligation for secure initial design and clear communication.

[VULN-UPDATE-RQ-1-06] Applicable when Update capability [UC-1](#), [UC-2](#), or [UC-3](#) is present. Update mechanisms shall prevent downgrade attacks through: (i) version checking before installation; (ii) anti-rollback counters; (iii)

minimum version enforcement; (iv) signed version metadata; and (v) hardware-backed version protection where available.

[VULN-UPDATE-RQ-1-07] Applicable when Update capability [UC-1](#), [UC-2](#), or [UC-3](#) is present. Updates shall maintain availability by: (i) backup and recovery mechanisms; (ii) atomic update operations; (iii) automatic rollback on failure; (iv) retention of previous working version; and (v) recovery mode preservation.

[VULN-NETWORK-RQ-1-08] Applicable when Network Boot capability [BS-3](#) is present. Network-delivered updates shall ensure: (i) encrypted transport protocols where feasible; (ii) server authentication; (iii) replay attack prevention; (iv) integrity verification after download; and (v) fallback to previous version on failure.

[VULN-HARDWARE-RQ-1-09] Applicable when Hardware Security capability [HS-1](#) or [HS-2](#) is present. Hardware-assisted update protection shall include: (i) hardware-backed rollback protection; (ii) secure storage of update keys; (iii) hardware verification of updates; (iv) tamper detection during update; and (v) hardware-enforced update policies.

[VULN-CONFIG-RQ-1-10] Applicable when Configuration-only Update capability [UC-1](#) is present. Boot managers that can only update configuration (not code) shall: (i) enable security policy updates through configuration; (ii) support certificate and key revocation; (iii) allow disabling of vulnerable features through configuration; (iv) provide configuration-based mitigations where possible; (v) document which vulnerabilities can/cannot be addressed via configuration; and (vi) maintain configuration update capability throughout product lifetime.

5.12.2.4 Output

- Authenticated and verified updates (where supported)
- Version and vulnerability status information
- Update success/failure indication
- Vulnerability advisories and documentation
- End-of-life status and guidance

5.12.2.5 Assessment criteria

- Verification that updates require authentication
- Testing of secure update channels and protocols
- Validation of anti-rollback mechanisms
- Confirmation of update failure recovery
- Review of vulnerability disclosure processes
- Documentation of update procedures or limitations
- Testing that unauthorized updates are rejected
- Verification of end-of-life procedures
- For non-updatable systems: Confirmation of clear documentation and compensating controls

5.13 Security Testing and Review

5.13.1 General

This subclause addresses the CRA requirement that manufacturers shall apply effective and regular tests and reviews of the security of the product with digital elements.

Security testing for boot managers requires specialized approaches due to:

- Pre-OS environment limitations

- Difficulty of runtime debugging
- Hardware dependencies
- Critical nature requiring extensive validation
- Need for both black-box and white-box testing

5.13.2 Security validation

5.13.2.1 General

Boot managers require rigorous security testing due to their critical role in establishing system trust. Testing must cover both functional security verification and resistance to attacks, within the constraints of pre-OS environments and limited debugging capabilities.

5.13.2.2 Input

- Boot manager implementation
- Security requirements and threat model
- Test vectors and known attack patterns
- Hardware security features (if present)

5.13.2.3 Requirements

[TEST-BASE-OB-1-01] Manufacturers shall perform security testing including: (i) cryptographic validation of all algorithms; (ii) verification of signature checking; (iii) testing of authentication mechanisms; (iv) validation of rollback protection; and (v) confirmation of secure failure modes.

[TEST-BASE-OB-1-02] Manufacturers shall conduct attack resistance testing including: (i) fuzzing of all inputs; (ii) fault injection testing where feasible; (iii) timing attack analysis; (iv) buffer overflow testing; and (v) bypass attempt validation.

[TEST-BASE-OB-1-03] Security reviews shall include: (i) code review for security vulnerabilities; (ii) third-party security assessment for critical implementations; (iii) architecture review against threat model; (iv) binary analysis of production builds; and (v) supply chain security review.

5.13.2.4 Output

- Security test results and reports
- Vulnerability assessment findings
- Code review documentation
- Compliance verification evidence

5.13.2.5 Assessment criteria

- Evidence of comprehensive security testing
- Documentation of test coverage
- Third-party assessment reports where applicable
- Remediation of identified vulnerabilities

5.14 Specific functional requirements

#FIXME Consolidate specific requirements

- Documentation what data persists after factory reset
- Provide method to cryptographically erase sensitive data
- Clear all cryptographic keys from hardware security components
- Enable verification that secure erasure completed successfully
- Support transfer of ownership scenarios
- Document any data that cannot be erased

Annex A (normative): Relationship between the present document and the essential requirements of EU Regulation 2024/2847

The present document has been prepared under the Commission's standardisation request C(2025) 618 final to provide one voluntary means of conforming to the requirements of Regulation (EU) No 2024/2847 (Cyber Resilience Act).

Once the present document is cited in the Official Journal of the European Union under that Regulation, compliance with the normative clauses of the present document given in Table A.1 confers, within the limits of the scope of the present document, a presumption of conformity with the corresponding requirements of that Regulation and associated EFTA regulations.

Relationship between the present document and the requirements of the CRA

No	Description	Requirements of Regulation	Clause(s) of the present document	U / C	Condition
Part I: Product Requirements					
X		Annex I, Part I(1)	X	X	
Part II: Vulnerability Handling Requirements					
X		Annex I, Part II(2)	X	X	

#FIXME Table relationship to CRA

Table: Table columns:

Requirement:

- **No:** A unique identifier for one row of the table which may be used to identify a requirement.
- **Description:** A textual reference to the requirement.
- **Requirements of Regulation:** Identification of article(s) defining the requirement in the Regulation.
- **Clause(s) of the present document:** Identification of clause(s) defining the requirement in the present document unless another document is referenced explicitly.

Requirement conditionality:

- **U/C:** Indicates whether the requirement is unconditionally applicable (U) or is conditional upon the manufacturer's claimed functionality of the equipment (C).
- **Condition:** Explains the conditions when the requirement is or is not applicable for a requirement which is classified "conditional".

Annex B (informative): Relationship between the present document and any related ETSI standards

B.1 Relationship to ETSI standards

Relationship between the present document and related ETSI standards

Standard	Title	Relationship to this document
CRA Verticals		
EN 304 626	Operating Systems	Boot managers transfer control to OS; boundary at kernel initialization
EN 304 635	Hypervisors and CRS	Hypervisors may include boot functionality; boot managers load hypervisors
XXX	XXX	XXX

#FIXME Table relationship to ETSI Standards

Annex C (informative): Risk identification and assessment methodology

#FIXME Annex C Risks

C.1 Assets

- Root of trust keys (vendor certificates)
- User-enrolled keys (enterprise certificates)
- Recovery keys
- Boot order and parameters
- Network boot settings
- Boot event log
- NVRAM/variable storage
- Boot cache

When hardware security component is present:

- Security register values
- Hardware security module state

#FIXME what are typical assets? starting with OSS, moving then to more sophisticated BMs

C.2 Threat actors

- Insider threats (supply chain, malicious admins)
- Nation state actors (sophisticated persistent threats)
- Organized crime (ransomware, cryptominers)
- Researchers/hackers (proof of concept, discovery)
- Opportunistic attackers (automated tools)
- Physical attacker
- Network attacker
- OS-level malware
- Firmware-level malware
- Supply chain

C.3 Boot-specific threats

- Pre-boot attacks
 - Boot code modification
 - Configuration manipulation

- Key injection/replacement
- TOCTOU-attacks
- Persistence attacks
 - Bootkit installation
 - Recovery mechanism compromise
 - Boot server impersonation
 - Boot image tampering
- Physical attacks
 - DMA attacks
 - Reset attacks against hardware security components
 - Fault injection
 - Flash chip replacement
- Supply chain attacks
 - Manufacturing backdoor
 - Compromised updates

C.4 Specific considerations for long-lifetime devices

- Cryptographic deprecation
- Key compromise accumulation
- Vulnerability accumulation
- Update mechanism decay
- Hardware degradation
- Threat evolution

#FIXME Assumptions

#FIXME Risk assessment

#FIXME Risk matrix (likelihood $\times$ impact)

Annex D (informative): Security profiles

#FIXME Security Profiles

This section provides informative guidance on common capability combinations found in boot manager implementations. While requirements are determined by individual capabilities as defined in Section 5.1.2, these profiles illustrate typical patterns in the industry.

D.1 Profile application guidance

When determining which capabilities to implement, manufacturers should consider:

- Deployment environment
- Operational requirements
- Compliance requirements
- Lifecycle considerations
- Cost constraints

#FIXME Which requirements address which threats

History

Document History		
Version	Date	Milestone
<Month year>	<#>	<Changes made>